TARGET SECURITY PROFILE

CLASS 2 AUTOMATED SYSTEM

SECURITY DEPARTMENT — TRAVEL AGENCY "UA-Travel"

Draft for Expert Review

Date prepared: 28/03/2026

Based on: Baseline Security Profile (SSSCIP, 2025) | ND TZI 3.6-006-24 | ASVB System Passport

LEGEND

Color coding for the 'Draft decision' field:

Keep unchanged	Parameters in the baseline profile are sufficient for this ICS — no changes required
Refine parameters	Specific numerical or qualitative parameters must be defined or adjusted
Add enhancement	Additional measures beyond the baseline minimum are recommended
Apply compensating control	An alternative control is proposed to satisfy the requirement
Clarification required	Insufficient data to make a final decision — input from the system owner is needed

Access Control

AC-2 Account Management	
1. Control identifier:	AC-2
2. Control name:	Account Management
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	h.1, h.2, h.3: 24 hours; j: at least quarterly; AC-2(3): no more than 72 hours / 90 days; AC-2(5): end of user's working day; AC-2(13): 30 minutes
5. Relevance to this ICS:	The system processes official information classified as 'For Official Use Only' (OU). Three main roles are identified: Head of Security Department, Information Security Specialist, System Administrator. The laptop requires separate mobile account management.
6. Security requirements addressed:	Confidentiality, integrity, and availability of official information. Role-based access management (Head of Security, IS Administrator, System Administrator).
7. Risks mitigated:	Unauthorized access via untimely deactivated or locked accounts; excessive privileges; dormant accounts.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	h.1, h.2, h.3: 24 hours; j: at least quarterly; AC-2(3): 1st param — no more than 72 hours, d: 90 days; AC-2(5): end of working day; AC-2(13): 30 minutes
10. Proposed enhancements:	Document an account register specifying roles, privileges, and authorizations within the Information Protection Plan.
11. Possible compensating control:	—
12. Rationale for the decision:	Baseline parameters are appropriate for the organization's size and the sensitivity level of the processed information.
13. Responsible role:	IS Administrator (Melnyk I.V.)
14. Implementation evidence / verification artifact:	Account register; appointment orders; account audit records; Loza-1 v.2.0 configuration
15. Information to be clarified with system owner:	Are there service/technical accounts (Windows services, antivirus) and are they included in the account register?

AC-3 Access Enforcement	
1. Control identifier:	AC-3
2. Control name:	Access Enforcement
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No specific numerical parameters — enforce approved authorizations for logical access
5. Relevance to this ICS:	Loza-1 v.2.0 implements access control. Hierarchy: System Administrator — IS Administrator — Regular User.
6. Security requirements addressed:	Confidentiality, integrity. Access only to authorized resources.
7. Risks mitigated:	Unauthorized access to official information through improper access segmentation.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	No change. Apply access attributes per the access matrix defined in the Information Protection Policy.
10. Proposed enhancements:	Document the access matrix specifying objects, subjects, and permitted operations.
11. Possible compensating control:	—
12. Rationale for the decision:	Loza-1 provides technical implementation. This control is mandatory and unchanged for systems of this class.

13. Responsible role:	System Administrator (Sydorenko I.M.); IS Administrator
14. Implementation evidence / verification artifact:	Loza-1 configuration files; access matrix; access event log
15. Information to be clarified with system owner:	Is the current access matrix defined for IT-Tour:Agency and shared network resources?

AC-4 Information Flow Enforcement

1. Control identifier:	AC-4
2. Control name:	Information Flow Enforcement
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — apply approved rules for managing information flows
5. Relevance to this ICS:	FortiGate 60F implements network-level flow control. The system has external network exposure (municipal telephone line exits the Controlled Zone).
6. Security requirements addressed:	Confidentiality, integrity. Prevention of unauthorized data transmission.
7. Risks mitigated:	Leakage of official information through uncontrolled information flows; unauthorized connections.
8. Draft decision:	**Add enhancement**
9. Proposed parameters for Target Security Profile:	No change to baseline parameters.
10. Proposed enhancements:	Develop an information flow diagram and define permitted/prohibited flows in FortiGate 60F rules. Apply deny-all-by-default in accordance with SC-7(5).
11. Possible compensating control:	—
12. Rationale for the decision:	The building is shared commercial infrastructure (shopping center), increasing the risk of unauthorized flows. The Gnom-VCh-01 noise generator mitigates acoustic leakage but does not address network threats.
13. Responsible role:	System Administrator; IS Administrator
14. Implementation evidence / verification artifact:	FortiGate firewall rules; information flow diagram; FortiGate logs
15. Information to be clarified with system owner:	Is Internet access permitted from workstations? If so — through which proxy or filtering mechanism?

AC-5 Separation of Duties

1. Control identifier:	AC-5
2. Control name:	Separation of Duties
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — identify duties requiring separation; establish authorization rules
5. Relevance to this ICS:	Three core roles: Head of Security, IS Administrator, System Administrator. Risk of combining critical roles in one person.
6. Security requirements addressed:	Integrity, accountability. Prevention of privilege abuse.
7. Risks mitigated:	A single individual may hold excessive privileges and commit violations without detection.
8. Draft decision:	**Clarification required**
9. Proposed parameters for Target Security Profile:	Define and document duties requiring separation (e.g., system administration vs. security administration).

10. Proposed enhancements:	Document specific incompatible functions and formalize them in the Information Protection Policy.
11. Possible compensating control:	If full separation is impossible in a small organization — compensating control: enhanced monitoring of privileged actions (AU-2, AU-9) and regular independent audits (CA-2).
12. Rationale for the decision:	Cannot confirm without a list of functions assigned to each individual. Mandatory clarification needed.
13. Responsible role:	Head of Security Department; IS Administrator
14. Implementation evidence / verification artifact:	Job descriptions; incompatible roles matrix; privileged action audit log
15. Information to be clarified with system owner:	Are there specific function lists per employee? Can one person simultaneously act as System Administrator and IS Administrator?

AC-6 / AC-6(1) / AC-6(7) Least Privilege	
1. Control identifier:	AC-6 / AC-6(1) / AC-6(7)
2. Control name:	Least Privilege
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — grant minimum necessary privileges; periodic review; AU-9(4)
5. Relevance to this ICS:	Applicable — three roles with different access levels to IT-Tour:Agency, Windows, FortiGate, Loza-1.
6. Security requirements addressed:	Confidentiality, integrity. Principle of least privilege.
7. Risks mitigated:	Privilege escalation; unauthorized actions by users with elevated rights.
8. Draft decision:	**Refine parameters**
9. Proposed parameters for Target Security Profile:	Review privileges at least quarterly for all accounts. Document in internal policy.
10. Proposed enhancements:	Document a minimum privilege matrix for each role in the system (Windows, IT-Tour, Loza-1, FortiGate).
11. Possible compensating control:	—
12. Rationale for the decision:	The baseline profile does not define a review frequency, leaving a gap. Quarterly review is appropriate for an OU-classified system.
13. Responsible role:	IS Administrator
14. Implementation evidence / verification artifact:	Privilege review records; access rights change log; role settings in Loza-1
15. Information to be clarified with system owner:	Does the System Administrator use separate non-privileged accounts for routine tasks?

AC-6(2) / AC-6(5) / AC-6(9) / AC-6(10) Least Privilege — Privileged Access	
1. Control identifier:	AC-6(2) / AC-6(5) / AC-6(9) / AC-6(10)
2. Control name:	Least Privilege — Privileged Access
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	AC-6(2): privileged functions; no numerical parameters
5. Relevance to this ICS:	System Administrator (Sydorenko I.M.) holds privileged access to all system components.
6. Security requirements addressed:	Integrity, accountability. Prevention of privileged account abuse.

7. Risks mitigated:	Unauthorized actions via privileged accounts; inability to detect violations.
8. Draft decision:	**Add enhancement**
9. Proposed parameters for Target Security Profile:	Introduce separate non-privileged accounts for daily tasks. Log all privileged account actions.
10. Proposed enhancements:	Configure Loza-1 and Windows Event Log to separately record all actions of privileged accounts. Store logs in a protected volume (AU-9).
11. Possible compensating control:	—
12. Rationale for the decision:	Small team size and role overlap increases risk of administrator abuse. Enhanced audit compensates for limited separation of duties.
13. Responsible role:	IS Administrator
14. Implementation evidence / verification artifact:	Windows audit settings; Loza-1 logs; privileged action review records
15. Information to be clarified with system owner:	Does the System Administrator use the admin account exclusively for administrative tasks, or also for routine work?

AC-7 Unsuccessful Logon Attempts

1. Control identifier:	AC-7
2. Control name:	Unsuccessful Logon Attempts
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	b: notify the responsible administrator. Number of attempts and time window — organizational parameters
5. Relevance to this ICS:	Applicable to all workstations (Windows 10 Pro) and the server.
6. Security requirements addressed:	Confidentiality. Prevention of password brute-force attacks.
7. Risks mitigated:	Brute-force password attacks; unauthorized access via authentication bypass.
8. Draft decision:	**Refine parameters**
9. Proposed parameters for Target Security Profile:	Define: no more than 5 failed attempts within 30 minutes; account lockout for 30 minutes or until administrator release; notify IS Administrator.
10. Proposed enhancements:	Configure Group Policy (Windows) according to defined parameters. Record in baseline configuration.
11. Possible compensating control:	—
12. Rationale for the decision:	The baseline profile leaves specific numerical parameters to the organization. For an OU-classified system, these must be defined in the Target Security Profile.
13. Responsible role:	System Administrator
14. Implementation evidence / verification artifact:	Group Policy configuration (Account Lockout Policy); Windows Event Log (EventID 4625)
15. Information to be clarified with system owner:	Is an account lockout policy currently configured in Windows 10?

AC-8 System Use Notification

1. Control identifier:	AC-8
2. Control name:	System Use Notification
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — display privacy and security warnings before granting system access

5. Relevance to this ICS:	Applicable to all workstations and the server. Mandatory for systems handling OU-classified information.
6. Security requirements addressed:	Legal accountability. Notifying users of monitoring and restrictions.
7. Risks mitigated:	Legal exposure for the organization; absence of confirmed user notification during incident investigation.
8. Draft decision:	**Add enhancement**
9. Proposed parameters for Target Security Profile:	Display an approved warning message on all workstations and the server prior to login.
10. Proposed enhancements:	Develop a Legal Notice text for Group Policy (Windows) referencing applicable legislation on protection of official information. Deploy via Group Policy on all nodes.
11. Possible compensating control:	—
12. Rationale for the decision:	The warning is mandatory for systems processing OU-classified information and is referenced during incident investigations.
13. Responsible role:	IS Administrator; System Administrator
14. Implementation evidence / verification artifact:	Group Policy settings (Interactive Logon: Message for users); approved warning text
15. Information to be clarified with system owner:	Has the warning text been approved by firm management?

AC-11 / AC-11(1) Device Lock

1. Control identifier:	AC-11 / AC-11(1)
2. Control name:	Device Lock
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	a: initiate device lock after no more than 30 minutes of inactivity; hide previously visible information on display
5. Relevance to this ICS:	Applicable to all three workstations including the laptop. Office in a shopping center — elevated risk of visual observation.
6. Security requirements addressed:	Confidentiality. Prevention of unauthorized viewing of information on unattended displays.
7. Risks mitigated:	Visual access by unauthorized persons; unauthorized access when workstation is left unattended.
8. Draft decision:	**Refine parameters**
9. Proposed parameters for Target Security Profile:	Lock after 15 minutes of inactivity (enhanced parameter due to limited physical control in shopping center environment); screensaver displaying warning message.
10. Proposed enhancements:	Configure Group Policy for automatic lock after 15 minutes. Recommend physical privacy screen filters for monitors, especially those facing windows.
11. Possible compensating control:	—
12. Rationale for the decision:	Location in a shopping center with 9 windows and public access increases visual observation risk. Reducing lockout to 15 minutes is a justified enhancement.
13. Responsible role:	System Administrator
14. Implementation evidence / verification artifact:	Group Policy settings (Screen Saver, Interactive Logon); laptop configuration check
15. Information to be clarified with system owner:	Are physical privacy filters installed on monitors and the laptop?

AC-12 Session Termination

1. Control identifier:	AC-12
2. Control name:	Session Termination
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — automatic session termination under defined conditions
5. Relevance to this ICS:	Applicable to all user and administrator sessions.
6. Security requirements addressed:	Confidentiality, integrity. Prevention of abandoned active sessions.
7. Risks mitigated:	Unauthorized access through an abandoned active session.
8. Draft decision:	**Refine parameters**
9. Proposed parameters for Target Security Profile:	Automatic session termination after 30 minutes of inactivity; session termination upon user logout.
10. Proposed enhancements:	Configure Group Policy and IT-Tour:Agency settings for automatic session termination.
11. Possible compensating control:	—
12. Rationale for the decision:	The parameter is not defined in the baseline profile — must be specified in the Target Security Profile.
13. Responsible role:	System Administrator
14. Implementation evidence / verification artifact:	Group Policy configuration; IT-Tour:Agency session settings
15. Information to be clarified with system owner:	Does IT-Tour:Agency v.5.4 support automatic session termination?

AC-17 / AC-17(3) / AC-17(4) Remote Access	
1. Control identifier:	AC-17 / AC-17(3) / AC-17(4)
2. Control name:	Remote Access
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — restrictions, authorization, routing through control points
5. Relevance to this ICS:	Presence of laptop (ThinkPad X1 Carbon) implies potential remote work. Whether remote access is permitted is unknown.
6. Security requirements addressed:	Confidentiality, integrity. Control of remote connections.
7. Risks mitigated:	Unauthorized remote connection; traffic interception; access via unsecured channels.
8. Draft decision:	**Clarification required**
9. Proposed parameters for Target Security Profile:	If permitted: only via VPN tunnel (FortiGate), with MFA, from authorized devices only. If not permitted: document the prohibition.
10. Proposed enhancements:	If RDP/SSH access exists — reconfigure through FortiGate VPN with two-factor authentication.
11. Possible compensating control:	—
12. Rationale for the decision:	The passport does not explicitly permit or prohibit remote access. Without this information, parameters cannot be determined.
13. Responsible role:	Head of Security; System Administrator
14. Implementation evidence / verification artifact:	FortiGate VPN rules; authorized remote connection register
15. Information to be clarified with system owner:	Is remote access to the system permitted? Is VPN used? From which devices and by which personnel?

AC-18 / AC-18(1) / AC-18(3) Wireless Access	
1. Control identifier:	AC-18 / AC-18(1) / AC-18(3)
2. Control name:	Wireless Access
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — restrictions, authorization, authentication and encryption
5. Relevance to this ICS:	Lenovo ThinkPad X1 Carbon Gen 9 has a built-in Wi-Fi adapter. The passport contains no information about wireless networking or explicit prohibition.
6. Security requirements addressed:	Confidentiality. Control of wireless connections.
7. Risks mitigated:	Unauthorized connection to shopping center Wi-Fi or external hotspots; traffic interception.
8. Draft decision:	**Clarification required**
9. Proposed parameters for Target Security Profile:	If permitted: WPA3 or WPA2-Enterprise, device authentication, encryption. If not permitted: document the prohibition and disable laptop Wi-Fi adapter.
10. Proposed enhancements:	Physically or programmatically disable Wi-Fi on the laptop if wireless access is not intended. Prohibit connections to public Wi-Fi networks in the shopping center.
11. Possible compensating control:	If disabling Wi-Fi is not feasible — deploy MDM agent or Group Policy to control wireless connections.
12. Rationale for the decision:	Office in a shopping center is an environment with numerous wireless networks. Absence of a documented policy is a risk.
13. Responsible role:	System Administrator; IS Administrator
14. Implementation evidence / verification artifact:	Laptop Wi-Fi adapter settings; Group Policy (Wireless Network Policy); wireless access permission/prohibition document
15. Information to be clarified with system owner:	Is there a wireless network in the firm's office? Is the laptop permitted to connect to Wi-Fi?

AC-19 / AC-19(5) Access Control for Mobile Devices	
1. Control identifier:	AC-19 / AC-19(5)
2. Control name:	Access Control for Mobile Devices
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	AC-19(5): 2nd param — all mobile computers/devices processing organizational data
5. Relevance to this ICS:	Lenovo ThinkPad X1 Carbon Gen 9 is a mobile device listed as a primary technical asset.
6. Security requirements addressed:	Confidentiality, integrity. Control of mobile devices accessing official information.
7. Risks mitigated:	Loss/theft of laptop with unencrypted disk; connection to unsecured networks; malware download.
8. Draft decision:	**Add enhancement**
9. Proposed parameters for Target Security Profile:	AC-19: define restrictions for the laptop (authorized connection only via FortiGate VPN; full disk encryption with BitLocker). AC-19(5): full disk encryption on the laptop.
10. Proposed enhancements:	1) Enable BitLocker on the laptop. 2) Develop and approve Mobile Device Usage Rules. 3) Verify ESET Endpoint Security is installed on the laptop. 4) Register the laptop in the technical asset inventory.
11. Possible compensating control:	—

12. Rationale for the decision:	The laptop processes official information (listed as a primary asset in the passport). Physical protection of mobile devices is critical, especially outside the Controlled Zone.
13. Responsible role:	System Administrator; IS Administrator
14. Implementation evidence / verification artifact:	BitLocker status; ESET license for laptop; Mobile Device Usage Rules
15. Information to be clarified with system owner:	Is BitLocker enabled on the laptop? Does the laptop leave the Controlled Zone?

AC-20 / AC-20(1) / AC-20(2) Use of External Systems	
1. Control identifier:	AC-20 / AC-20(1) / AC-20(2)
2. Control name:	Use of External Systems
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — prohibition, conditions, verification of security measures
5. Relevance to this ICS:	The system may use external cloud services or network resources. Tourism operations often involve interaction with external booking systems.
6. Security requirements addressed:	Confidentiality. Control of access to external resources.
7. Risks mitigated:	Leakage of official information through external systems without proper agreements and security checks.
8. Draft decision:	**Clarification required**
9. Proposed parameters for Target Security Profile:	Document the list of permitted external systems, conditions of use, and corresponding agreements.
10. Proposed enhancements:	Develop an external systems register and conclude data processing/protection agreements with their operators.
11. Possible compensating control:	—
12. Rationale for the decision:	IT-Tour:Agency may interact with external systems (GDS booking systems). Without a list of such systems, compliance cannot be confirmed.
13. Responsible role:	Head of Security Department
14. Implementation evidence / verification artifact:	External systems register; data processing agreements; FortiGate rules blocking unauthorized resources
15. Information to be clarified with system owner:	Which external systems does IT-Tour:Agency interact with? Are data protection agreements in place?

AC-22 Publicly Accessible Content	
1. Control identifier:	AC-22
2. Control name:	Publicly Accessible Content
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	d: quarterly or as new information becomes available
5. Relevance to this ICS:	The firm may have a public website or social media. Risk of inadvertent publication of OU-classified information.
6. Security requirements addressed:	Confidentiality. Prevention of publishing official information publicly.
7. Risks mitigated:	Accidental publication of OU-classified information in the public domain.
8. Draft decision:	**Keep unchanged**

9. Proposed parameters for Target Security Profile:	d: quarterly or as new information becomes available
10. Proposed enhancements:	Include public content review in the quarterly IS audit plan.
11. Possible compensating control:	—
12. Rationale for the decision:	The parameter is appropriate for the organization's needs.
13. Responsible role:	IS Administrator
14. Implementation evidence / verification artifact:	Quarterly public content review reports
15. Information to be clarified with system owner:	Does the firm have a public website or official social media accounts?

Awareness and Training

AT-2 / AT-2(2) / AT-2(3) Literacy Training and Awareness	
1. Control identifier:	AT-2 / AT-2(2) / AT-2(3)
2. Control name:	Literacy Training and Awareness
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	a.1: at least once a year
5. Relevance to this ICS:	All three employees require training. Especially important given the sensitivity of OU-classified information and the insider threat risk.
6. Security requirements addressed:	Confidentiality, integrity. Personnel awareness of threats and security rules.
7. Risks mitigated:	Social engineering, phishing, inadvertent disclosure of information due to lack of policy awareness.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	a.1: at least once a year; training upon hiring; training on social engineering and insider threats
10. Proposed enhancements:	Require confirmation of training completion (signature/test) and retain documentation in the security file.
11. Possible compensating control:	—
12. Rationale for the decision:	Parameters are appropriate for the organization's size and sensitivity level.
13. Responsible role:	IS Administrator
14. Implementation evidence / verification artifact:	Training records; signed acknowledgment sheets; knowledge assessment tests
15. Information to be clarified with system owner:	Have training sessions been conducted since the current personnel were appointed (from January 2023)?

AT-3 Role-Based Training	
1. Control identifier:	AT-3
2. Control name:	Role-Based Training
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	a.1: at least annually
5. Relevance to this ICS:	Specific roles: IS Administrator (Melnyk I.V.) requires training on Loza-1 administration, FortiGate, and incident response procedures.

6. Security requirements addressed:	Confidentiality, integrity, availability. Competence of security personnel.
7. Risks mitigated:	Inadvertent configuration errors due to insufficient competence; inadequate incident response.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	a.1: at least annually; training prior to system access authorization; training when system changes occur
10. Proposed enhancements:	Document a role-based training program for each position in the ASVB.
11. Possible compensating control:	—
12. Rationale for the decision:	Parameters are appropriate for the organization's needs.
13. Responsible role:	Head of Security Department
14. Implementation evidence / verification artifact:	Role-based training programs; certificates/training records
15. Information to be clarified with system owner:	Have Melnyk I.V. and Sydorenko I.M. received training on specific protection tools (Loza-1, FortiGate)?

Audit and Accountability

AU-2 Event Logging	
1. Control identifier:	AU-2
2. Control name:	Event Logging
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — define audit event list; periodically review
5. Relevance to this ICS:	Windows 10, Loza-1, FortiGate, ESET — all have logging capabilities. An event list must be defined for the OU-classified system.
6. Security requirements addressed:	Accountability, integrity. Recording of security events.
7. Risks mitigated:	Undetected violations due to absence of logging for critical events.
8. Draft decision:	**Add enhancement**
9. Proposed parameters for Target Security Profile:	Approve an audit event list including: logon/logoff, access failures, configuration changes, service start/stop, access to OU-classified files, privileged user actions.
10. Proposed enhancements:	Develop an ASVB Audit Event List and attach it to the Information Protection Plan. Configure Windows Advanced Audit Policy.
11. Possible compensating control:	—
12. Rationale for the decision:	The baseline profile leaves the event list to the organization. For the Target Security Profile, it must be explicitly defined.
13. Responsible role:	System Administrator; IS Administrator
14. Implementation evidence / verification artifact:	Approved audit event list; Advanced Audit Policy settings; Loza-1 configuration
15. Information to be clarified with system owner:	Is audit currently configured in Windows and Loza-1? Are actions on OU-classified files being recorded?

AU-3 / AU-3(1) Content of Audit Records	
1. Control identifier:	AU-3 / AU-3(1)
2. Control name:	Content of Audit Records

3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	Type, time, location, source, outcome, result, and subject identifier of the event
5. Relevance to this ICS:	Standard Windows Event Log and Loza-1 fields should satisfy these requirements.
6. Security requirements addressed:	Accountability. Sufficiency of data for incident investigation.
7. Risks mitigated:	Incomplete records that prevent incident investigation.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	No change. Verify that existing log records comply with AU-3 requirements.
10. Proposed enhancements:	Audit existing log records to confirm they contain all required fields per AU-3.
11. Possible compensating control:	—
12. Rationale for the decision:	The baseline parameters are clearly defined and comply with the standard.
13. Responsible role:	IS Administrator
14. Implementation evidence / verification artifact:	Sample log records from Windows, Loza-1, FortiGate; verification of required field presence
15. Information to be clarified with system owner:	—

AU-11 Audit Record Retention

1. Control identifier:	AU-11
2. Control name:	Audit Record Retention
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	Retain in accordance with retention policy
5. Relevance to this ICS:	Applicable to all components: Windows Event Log, Loza-1, FortiGate.
6. Security requirements addressed:	Accountability. Retrospective incident analysis.
7. Risks mitigated:	Loss of logs due to disk overflow or absence of archiving.
8. Draft decision:	**Refine parameters**
9. Proposed parameters for Target Security Profile:	Retain audit records for at least 1 year (online — 90 days; archive — up to 1 year). Develop and approve an Audit Record Retention Policy.
10. Proposed enhancements:	Configure automatic log archiving to HP ProLiant DL360 Gen10 server. Protect archives per AU-9.
11. Possible compensating control:	—
12. Rationale for the decision:	The retention period is not defined in the baseline profile — must be specified in the Target Security Profile.
13. Responsible role:	System Administrator
14. Implementation evidence / verification artifact:	Log size and archiving settings; Audit Record Retention Policy
15. Information to be clarified with system owner:	How much disk space is allocated for logs? Is automatic archiving configured?

AU-12 Audit Record Generation

1. Control identifier:	AU-12
2. Control name:	Audit Record Generation

3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	a: all information systems and network components
5. Relevance to this ICS:	Covers: HP ProLiant DL360, Dell OptiPlex, ThinkPad, HP LaserJet, FortiGate, Cisco Catalyst 2960-L.
6. Security requirements addressed:	Accountability. Complete audit coverage of all system components.
7. Risks mitigated:	Missing events due to absence of logging on individual components.
8. Draft decision:	**Add enhancement**
9. Proposed parameters for Target Security Profile:	a: all system components, including Cisco Catalyst 2960-L and HP LaserJet Pro M404dn
10. Proposed enhancements:	Verify and document the presence and activity of logging on all components, including the printer (print job accounting) and network switch.
11. Possible compensating control:	—
12. Rationale for the decision:	The printer is an output device for OU-classified information and requires separate print job accounting. The switch is a critical network component.
13. Responsible role:	System Administrator
14. Implementation evidence / verification artifact:	Component list with confirmed logging; syslog configuration on FortiGate and Cisco
15. Information to be clarified with system owner:	Is print job logging enabled on the HP LaserJet? Is syslog configured on Cisco Catalyst 2960-L?

AU-5 Response to Audit Logging Process Failures

1. Control identifier:	AU-5
2. Control name:	Response to Audit Logging Process Failures
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	a.2: in near real-time
5. Relevance to this ICS:	Important for a small organization with limited staff — notifications must be automated.
6. Security requirements addressed:	Availability, accountability. Continuity of logging.
7. Risks mitigated:	Missing critical events due to audit system failure without timely notification.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	Notify IS Administrator in near real-time upon audit processing failure
10. Proposed enhancements:	Configure ESET or FortiGate to send alerts when logs reach critical capacity levels.
11. Possible compensating control:	—
12. Rationale for the decision:	The parameter meets the system's requirements.
13. Responsible role:	System Administrator
14. Implementation evidence / verification artifact:	Alert configuration settings (email/SNMP); alert test results
15. Information to be clarified with system owner:	Is a critical security event notification system configured?

AU-6 / AU-6(3) Audit Record Review, Analysis, and Reporting

1. Control identifier:	AU-6 / AU-6(3)
2. Control name:	Audit Record Review, Analysis, and Reporting
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	a.1: at least weekly (7 days)
5. Relevance to this ICS:	Small staff — weekly review is realistic and sufficient.
6. Security requirements addressed:	Accountability. Timely detection of violations.
7. Risks mitigated:	Late detection of attacks or violations due to irregular log analysis.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	a.1: at least weekly; document review results in weekly reports
10. Proposed enhancements:	Develop a weekly security status report template including key event analysis.
11. Possible compensating control:	—
12. Rationale for the decision:	The weekly cycle is appropriate for the organization's size and staff resources.
13. Responsible role:	IS Administrator
14. Implementation evidence / verification artifact:	Weekly log analysis reports; security review log
15. Information to be clarified with system owner:	—

AU-7 Audit Record Reduction and Report Generation

1. Control identifier:	AU-7
2. Control name:	Audit Record Reduction and Report Generation
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — support for review, analysis, and reporting
5. Relevance to this ICS:	Available tools: Windows Event Viewer, FortiGate Logs provide basic functionality.
6. Security requirements addressed:	Accountability. Efficiency of log analysis.
7. Risks mitigated:	Missing important events due to excessive volume of unfiltered records.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	Use built-in filtering and reporting tools of Windows Event Log and FortiGate
10. Proposed enhancements:	Consider deploying a centralized log collection server (e.g., Syslog server on HP ProLiant) to aggregate logs from all components.
11. Possible compensating control:	—
12. Rationale for the decision:	Existing tools provide baseline functionality. Centralization would improve efficiency.
13. Responsible role:	System Administrator
14. Implementation evidence / verification artifact:	Log analysis procedure; event filter settings
15. Information to be clarified with system owner:	Is a centralized log collection server in use?

AU-8 Time Stamps

1. Control identifier:	AU-8
2. Control name:	Time Stamps
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	Use UTC or fixed offset; granularity — organizational parameter
5. Relevance to this ICS:	Time synchronization is critical for correlating events across Windows, FortiGate, Loza-1.
6. Security requirements addressed:	Accountability. Accuracy and reliability of timestamps.
7. Risks mitigated:	Timestamp inconsistencies between components prevent event correlation during investigations.
8. Draft decision:	**Refine parameters**
9. Proposed parameters for Target Security Profile:	Timestamp granularity: 1 second; synchronization via NTP server (FortiGate as NTP client); time zone UTC+2/UTC+3 (Kyiv time) with fixed offset.
10. Proposed enhancements:	Configure Windows Time Service on all nodes and FortiGate to synchronize with a trusted NTP source. Verify time accuracy monthly.
11. Possible compensating control:	—
12. Rationale for the decision:	Timestamp accuracy is critical for incident investigation and forensic analysis.
13. Responsible role:	System Administrator
14. Implementation evidence / verification artifact:	NTP configuration on Windows and FortiGate; time synchronization verification
15. Information to be clarified with system owner:	Is NTP time synchronization configured on all system components?

AU-9 / AU-9(4) Protection of Audit Information

1. Control identifier:	AU-9 / AU-9(4)
2. Control name:	Protection of Audit Information
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	Protect from unauthorized access, modification, and deletion; access only for privileged subset
5. Relevance to this ICS:	Logs on Windows and FortiGate must be protected from modification, including by the System Administrator.
6. Security requirements addressed:	Integrity, accountability. Preventing concealment of violation traces.
7. Risks mitigated:	Deletion or modification of logs to conceal unauthorized actions.
8. Draft decision:	**Add enhancement**
9. Proposed parameters for Target Security Profile:	Log protection: read-only for standard users; log management only for a dedicated privileged account (IS Administrator).
10. Proposed enhancements:	1) Configure Windows log permissions so that the System Administrator cannot delete/clear logs without IS Administrator authorization. 2) Archive logs to a protected server volume with separate access rights.
11. Possible compensating control:	—
12. Rationale for the decision:	Small team and role overlap increases risk of log tampering. Separating audit rights is a critical compensating measure.
13. Responsible role:	IS Administrator
14. Implementation evidence / verification artifact:	Windows Event Log ACL settings; log access permissions configuration

15. Information to be clarified with system owner:	Does the System Administrator currently have rights to clear Windows Security logs?

Configuration Management

CM-2 Baseline Configuration	
1. Control identifier:	CM-2
2. Control name:	Baseline Configuration
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	b.1: at least annually
5. Relevance to this ICS:	The system has a specific list of hardware and software components (ASVB passport). The baseline configuration must be maintained.
6. Security requirements addressed:	Integrity. System configuration control.
7. Risks mitigated:	Unauthorized configuration changes; deviation from the approved state.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	b.1: at least annually; update upon component installation or modification
10. Proposed enhancements:	Record the current baseline configuration of all components (software versions, security settings, service states) in an 'ASVB Baseline Configuration' document.
11. Possible compensating control:	—
12. Rationale for the decision:	The passport already contains a component list — it needs to be supplemented with configuration parameters.
13. Responsible role:	System Administrator; IS Administrator
14. Implementation evidence / verification artifact:	'ASVB Baseline Configuration' document; annual review reports
15. Information to be clarified with system owner:	Are current Windows and FortiGate security settings documented?

CM-6 Configuration Settings	
1. Control identifier:	CM-6
2. Control name:	Configuration Settings
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	c.1: all configurable system components
5. Relevance to this ICS:	All components: Windows 10 (GP), FortiGate (rules), Loza-1, ESET, IT-Tour:Agency, Cisco 2960-L.
6. Security requirements addressed:	Integrity, confidentiality. Minimizing the attack surface.
7. Risks mitigated:	Insecure or suboptimal configuration settings creating vulnerabilities.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	c.1: all configurable components; document any deviations from most restrictive settings
10. Proposed enhancements:	Apply CIS Benchmarks or DISA STIG as the basis for Windows 10 and FortiGate settings.

11. Possible compensating control:	—
12. Rationale for the decision:	The parameter covers all system components.
13. Responsible role:	System Administrator
14. Implementation evidence / verification artifact:	Baseline configuration; deviation documentation with justifications
15. Information to be clarified with system owner:	—

CM-3 Configuration Change Control

1. Control identifier:	CM-3
2. Control name:	Configuration Change Control
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	e: 1 year (retention of change records)
5. Relevance to this ICS:	The passport contains a maintenance and repair log. The change management process must be formalized.
6. Security requirements addressed:	Integrity. Controlled system modifications.
7. Risks mitigated:	Unauthorized or undocumented configuration changes that compromise security.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	e: retain configuration change records for at least 1 year
10. Proposed enhancements:	Establish a formal change management process (Change Request, Head of Department approval, testing, documentation). Use Passport Section 7 to record all changes.
11. Possible compensating control:	—
12. Rationale for the decision:	The parameter is clear and meets requirements.
13. Responsible role:	IS Administrator; Head of Security Department
14. Implementation evidence / verification artifact:	Configuration change log (Passport Section 7); change request forms
15. Information to be clarified with system owner:	—

CM-4 / CM-4(2) Impact Analysis

1. Control identifier:	CM-4 / CM-4(2)
2. Control name:	Impact Analysis
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — analyze security impact before implementing changes
5. Relevance to this ICS:	Applicable for software updates, FortiGate configuration changes, Loza-1 updates.
6. Security requirements addressed:	Integrity, confidentiality. Prevention of security weakening through changes.
7. Risks mitigated:	Implementing changes that reduce protection or disrupt security controls.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	Mandatory impact analysis before any significant change; document analysis results

10. Proposed enhancements:	Develop a security impact analysis checklist for inclusion in the change request form.
11. Possible compensating control:	—
12. Rationale for the decision:	Baseline profile parameters are sufficient.
13. Responsible role:	IS Administrator
14. Implementation evidence / verification artifact:	Impact analysis checklists; change request forms with security section
15. Information to be clarified with system owner:	—

CM-5 Access Restrictions for Change

1. Control identifier:	CM-5
2. Control name:	Access Restrictions for Change
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — physical and logical access restrictions for changes
5. Relevance to this ICS:	Configuration changes must be made only by authorized personnel (System Administrator with IS Administrator approval).
6. Security requirements addressed:	Integrity. Prevention of unauthorized system changes.
7. Risks mitigated:	Unauthorized changes to system or security control configurations.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	Define: configuration changes are made only by System Administrator after IS Administrator authorization and Head of Department approval
10. Proposed enhancements:	Establish the procedure in internal instructions.
11. Possible compensating control:	—
12. Rationale for the decision:	The parameter is appropriate for the organization's structure.
13. Responsible role:	Head of Security Department
14. Implementation evidence / verification artifact:	Approved change management procedure; authorized change records
15. Information to be clarified with system owner:	—

CM-7 / CM-7(1) / CM-7(5) Least Functionality

1. Control identifier:	CM-7 / CM-7(1) / CM-7(5)
2. Control name:	Least Functionality
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	b: all unnecessary functions/ports/protocols; CM-7(1)a: at least annually; CM-7(5)c: at least annually
5. Relevance to this ICS:	Windows 10 Pro and FortiGate must be configured to minimal functionality. The whitelist must include only: Windows, Office, IT-Tour, ESET, Loza-1.
6. Security requirements addressed:	Confidentiality, integrity. Minimizing the attack surface.
7. Risks mitigated:	Unnecessary services, ports, and protocols that can be exploited for attacks.
8. Draft decision:	**Refine parameters**
9. Proposed parameters for Target Security Profile:	Approve a list of permitted Windows services, ports, and protocols; approve software whitelist: Windows 10 Pro, MS Office 2021, IT-Tour:Agency v.5.4, ESET Endpoint

	Security v.10.0, Loza-1 v.2.0; CM-7(5)c: at least annually and upon any system changes
10. Proposed enhancements:	Disable unused Windows services (e.g., Telnet, Remote Registry if not needed, Bluetooth). Block unused ports on FortiGate and Cisco.
11. Possible compensating control:	—
12. Rationale for the decision:	Minimal functionality is the cornerstone of protection. The passport contains a software list — it can serve as the basis for the whitelist.
13. Responsible role:	System Administrator
14. Implementation evidence / verification artifact:	Permitted services list; software whitelist (based on Passport Section 5.2); annual review reports
15. Information to be clarified with system owner:	Are unused Windows services disabled? Which ports are open on FortiGate?

CM-8 / CM-8(1) System Component Inventory

1. Control identifier:	CM-8 / CM-8(1)
2. Control name:	System Component Inventory
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	a.5: hardware specs, software, license info, owner, hostname for network devices; b: at least annually
5. Relevance to this ICS:	Passport Sections 5.1–5.4 contain a detailed inventory. Maintenance required.
6. Security requirements addressed:	Integrity. System composition control.
7. Risks mitigated:	Unauthorized components in the system; absence of license control.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	b: at least annually; update upon every component change
10. Proposed enhancements:	Supplement the passport: add hostnames, IP addresses, license keys. Verify actual state against documentation annually.
11. Possible compensating control:	—
12. Rationale for the decision:	The passport already contains detailed inventory — only network parameters need to be added and currency maintained.
13. Responsible role:	System Administrator; IS Administrator
14. Implementation evidence / verification artifact:	Updated ASVB passport (Sections 5.1–5.4); annual inventory audit records
15. Information to be clarified with system owner:	Are IP addresses and hostnames of all devices recorded in the passport?

CM-12 Information Location

1. Control identifier:	CM-12
2. Control name:	Information Location
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — identify location of official information and system components
5. Relevance to this ICS:	OU-classified information is stored on the server (HP ProLiant) and potentially on the laptop.
6. Security requirements addressed:	Confidentiality. Awareness of where information is stored.

7. Risks mitigated:	Uncontrolled copying of OU-classified information to unsecured media or devices.
8. Draft decision:	**Add enhancement**
9. Proposed parameters for Target Security Profile:	Document the location of OU-classified information: server (specific directories), workstations, laptop. Prohibit local storage on laptop without encryption.
10. Proposed enhancements:	Develop an information resource location diagram. Apply Group Policies to restrict OU-classified information storage to the protected server only.
11. Possible compensating control:	—
12. Rationale for the decision:	The laptop is a mobile device that may leave the premises — unauthorized local storage on it is a risk.
13. Responsible role:	IS Administrator
14. Implementation evidence / verification artifact:	Information resource location diagram; Group Policy settings (Folder Redirection)
15. Information to be clarified with system owner:	Are there local copies of OU-classified files on the laptop? Is folder redirection to the server configured?

CM-2(7) Baseline Configuration — High-Risk Areas	
1. Control identifier:	CM-2(7)
2. Control name:	Baseline Configuration — High-Risk Areas
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — special configurations when traveling to high-risk zones
5. Relevance to this ICS:	The laptop may be used outside the Controlled Zone. Tourism operations may involve business travel.
6. Security requirements addressed:	Confidentiality, integrity. Protection when operating in high-risk zones.
7. Risks mitigated:	Laptop compromise when outside the Controlled Zone; malware installation.
8. Draft decision:	**Clarification required**
9. Proposed parameters for Target Security Profile:	Define a minimum laptop configuration for use outside the Controlled Zone; introduce post-travel inspection procedure (antivirus scan, integrity check).
10. Proposed enhancements:	Develop a travel configuration procedure for the laptop (disable unsecured services, verify BitLocker, prohibit external network connections without VPN).
11. Possible compensating control:	—
12. Rationale for the decision:	Without a specific policy for laptop use outside the Controlled Zone, parameters cannot be determined.
13. Responsible role:	IS Administrator
14. Implementation evidence / verification artifact:	Travel laptop usage procedure; post-return inspection checklist
15. Information to be clarified with system owner:	Does the laptop leave the Controlled Zone? For what purposes and by whom?

Identification and Authentication

IA-2 / IA-11 Identification and Authentication (Organizational Users)	
1. Control identifier:	IA-2 / IA-11
2. Control name:	Identification and Authentication (Organizational Users)
3. Included in baseline profile:	Yes

4. Minimum baseline parameters:	Unique identification and authentication; re-authentication under defined circumstances
5. Relevance to this ICS:	Loza-1 v.2.0 provides identification and authentication. Windows 10 — basic authentication.
6. Security requirements addressed:	Confidentiality, integrity. Confirmation of user identity.
7. Risks mitigated:	Unauthorized access via compromised or guessed credentials.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	Unique identifier per user; re-authentication upon session resumption after lock
10. Proposed enhancements:	Ensure Loza-1 and Windows enforce unique identification — shared accounts must not be permitted.
11. Possible compensating control:	—
12. Rationale for the decision:	The parameters are sufficient for a system of this class.
13. Responsible role:	System Administrator
14. Implementation evidence / verification artifact:	Account register (uniqueness verified); Loza-1 configuration
15. Information to be clarified with system owner:	Are shared accounts (e.g., 'admin') used in Windows or IT-Tour?

IA-3 Device Identification and Authentication

1. Control identifier:	IA-3
2. Control name:	Device Identification and Authentication
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — unique device identification and authentication before connection
5. Relevance to this ICS:	Cisco Catalyst 2960-L connects all components. New device connection control is required.
6. Security requirements addressed:	Confidentiality. Prevention of unauthorized device connections.
7. Risks mitigated:	Connection of unauthorized devices to the system network.
8. Draft decision:	**Add enhancement**
9. Proposed parameters for Target Security Profile:	Configure 802.1X or MAC filtering on Cisco Catalyst 2960-L to control device connections.
10. Proposed enhancements:	Implement MAC filtering on all Cisco Catalyst 2960-L ports, allowing only registered MAC addresses. Block unused switch ports.
11. Possible compensating control:	If 802.1X is unavailable — physical access control to the switch (metal cabinet, access log) as a compensating control.
12. Rationale for the decision:	The switch is housed in a metal cabinet (physical control exists), but programmatic device connection control is absent.
13. Responsible role:	System Administrator
14. Implementation evidence / verification artifact:	Cisco configuration (port security / MAC filtering); authorized MAC address list
15. Information to be clarified with system owner:	Is port-security configured on Cisco Catalyst 2960-L?

IA-2(1) / IA-2(2) Multi-Factor Authentication

1. Control identifier:	IA-2(1) / IA-2(2)

2. Control name:	Multi-Factor Authentication
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	Implement MFA for access to system accounts (privileged and non-privileged)
5. Relevance to this ICS:	Loza-1 v.2.0 may support hardware tokens or certificates. Verification required.
6. Security requirements addressed:	Confidentiality. Enhanced authentication.
7. Risks mitigated:	Password compromise provides full access without MFA.
8. Draft decision:	**Clarification required**
9. Proposed parameters for Target Security Profile:	For privileged accounts — mandatory MFA. For non-privileged — MFA or enhanced password policy with replay resistance.
10. Proposed enhancements:	If Loza-1 supports hardware tokens — deploy for administrators. If not — consider certificates (smart card) or Windows Hello for Business.
11. Possible compensating control:	If MFA is not feasible — enhanced password policy (≥16 characters for admins) + mandatory audit of privileged user actions.
12. Rationale for the decision:	Loza-1 MFA capabilities are unknown without additional information.
13. Responsible role:	IS Administrator; System Administrator
14. Implementation evidence / verification artifact:	Loza-1 technical documentation; MFA configuration; list of privileged accounts with MFA enabled
15. Information to be clarified with system owner:	Does Loza-1 v.2.0 support multi-factor authentication? Which MFA methods are available in the system?

IA-2(8) Replay-Resistant Authentication

1. Control identifier:	IA-2(8)
2. Control name:	Replay-Resistant Authentication
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	At minimum for privileged accounts
5. Relevance to this ICS:	Kerberos mechanism in Windows 10 / Active Directory provides replay resistance.
6. Security requirements addressed:	Confidentiality. Prevention of replay attacks.
7. Risks mitigated:	Interception and reuse of authentication tokens.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	Replay resistance for privileged accounts via Windows Kerberos mechanisms
10. Proposed enhancements:	Ensure Kerberos (not NTLM) is used for authentication in the domain or Loza-1.
11. Possible compensating control:	—
12. Rationale for the decision:	Windows 10 Pro with Kerberos provides this requirement natively.
13. Responsible role:	System Administrator
14. Implementation evidence / verification artifact:	Windows authentication configuration; absence of NTLM in event logs
15. Information to be clarified with system owner:	Is Active Directory configured, or is local Windows authentication used?

IA-4 / IA-4(4) Identifier Management

1. Control identifier:	IA-4 / IA-4(4)

2. Control name:	Identifier Management
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	d: at least 1 year for individuals, groups, roles; unique identification of person status
5. Relevance to this ICS:	Three registered officials. Identifier reuse control is required.
6. Security requirements addressed:	Accountability. Unique identification of all subjects.
7. Risks mitigated:	Identifier reuse complicating accountability.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	d: at least 1 year; mark identifiers indicating role/status (e.g., admin_melnyk for administrators)
10. Proposed enhancements:	Define an account naming convention in the internal policy.
11. Possible compensating control:	—
12. Rationale for the decision:	The parameter meets the system's requirements.
13. Responsible role:	IS Administrator
14. Implementation evidence / verification artifact:	Identifier register with creation/deactivation dates
15. Information to be clarified with system owner:	—

IA-5(1) Authenticator Management — Password-Based Authentication

1. Control identifier:	IA-5(1)
2. Control name:	Authenticator Management — Password-Based Authentication
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	a: at least quarterly; h: 12-character set with uppercase, lowercase, digits, special chars; at least 1 of each; change ≥50% of characters
5. Relevance to this ICS:	The passport confirms the existence of a password policy. Compliance with parameters requires verification.
6. Security requirements addressed:	Confidentiality. Password strength against guessing.
7. Risks mitigated:	Weak passwords or compromised credentials.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	a: update compromised passwords list at least quarterly; h: 12-character password with all character types; change ≥50% upon renewal
10. Proposed enhancements:	Verify current Group Policy (Password Policy) settings and align with requirements. Add compromised password checking (Have I Been Pwned API or local list).
11. Possible compensating control:	—
12. Rationale for the decision:	The passport confirms the existence of a password policy — compliance with specific IA-5(1) parameters must be verified.
13. Responsible role:	System Administrator
14. Implementation evidence / verification artifact:	Group Policy settings (Password Policy); minimum length, complexity, expiration
15. Information to be clarified with system owner:	What is the current minimum password length in Group Policy? Does it satisfy the 12-character requirement?

IA-6 Authenticator Feedback

1. Control identifier:	IA-6
2. Control name:	Authenticator Feedback
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — obscured feedback during authentication
5. Relevance to this ICS:	Windows 10 and Loza-1 must obscure password characters during entry.
6. Security requirements addressed:	Confidentiality. Prevention of visual password interception.
7. Risks mitigated:	Shoulder-surfing observation of password entry.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	Mask characters during authentication credential entry across all components
10. Proposed enhancements:	Verify password display settings in IT-Tour:Agency and Loza-1.
11. Possible compensating control:	—
12. Rationale for the decision:	Standard feature of Windows and most software.
13. Responsible role:	IS Administrator
14. Implementation evidence / verification artifact:	Password display settings verification across all applications
15. Information to be clarified with system owner:	Are password characters obscured in all system applications (especially IT-Tour:Agency)?

IA-5 Authenticator Management	
1. Control identifier:	IA-5
2. Control name:	Authenticator Management
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	f.1: no more than 180 days for passwords
5. Relevance to this ICS:	Password expiration for all system accounts.
6. Security requirements addressed:	Confidentiality. Limiting the window of compromise.
7. Risks mitigated:	Extended use of compromised passwords.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	f.1: password expiration no more than 180 days (6 months); change default passwords upon first use
10. Proposed enhancements:	Configure Group Policy (Maximum Password Age: 180 days). Verify and change all default passwords on FortiGate, Cisco, and ESET management console.
11. Possible compensating control:	—
12. Rationale for the decision:	The parameter meets baseline profile requirements.
13. Responsible role:	System Administrator
14. Implementation evidence / verification artifact:	Group Policy settings (Maximum Password Age); confirmation of default password changes
15. Information to be clarified with system owner:	Have default passwords been changed on FortiGate (admin/admin) and Cisco?

Incident Response

IR-4 Incident Handling	
1. Control identifier:	IR-4
2. Control name:	Incident Handling
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — incident response system per incident response plan
5. Relevance to this ICS:	Small staff — clear role assignment during incident response is critical.
6. Security requirements addressed:	Availability, integrity, confidentiality. Minimizing damage from incidents.
7. Risks mitigated:	Unpreparedness for incident response; delayed system recovery.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	Implement incident response system in accordance with the approved plan (IR-8)
10. Proposed enhancements:	Develop an Incident Response Procedure with specific step-by-step actions for each role.
11. Possible compensating control:	—
12. Rationale for the decision:	Baseline parameter is sufficient. Detail is provided by IR-8.
13. Responsible role:	Head of Security Department
14. Implementation evidence / verification artifact:	Approved Incident Response Plan; tabletop exercise results
15. Information to be clarified with system owner:	—

IR-5 / IR-6 / IR-7 Incident Monitoring and Reporting	
1. Control identifier:	IR-5 / IR-6 / IR-7
2. Control name:	Incident Monitoring and Reporting
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	IR-6 a: 2 hours for reporting
5. Relevance to this ICS:	Small staff — identifying who is responsible for receiving and recording incidents is critical.
6. Security requirements addressed:	Availability, accountability. Timely response and escalation.
7. Risks mitigated:	Delayed incident reporting; insufficient response support.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	a: 2 hours for reporting an incident to the internal response service; maintain an incident register
10. Proposed enhancements:	Define and document contact details for the incident response service (CERT-UA or other authorized body per applicable legislation).
11. Possible compensating control:	—
12. Rationale for the decision:	The parameter meets system requirements.
13. Responsible role:	IS Administrator (Melnyk I.V.)
14. Implementation evidence / verification artifact:	Incident register; response service contacts; notification confirmations
15. Information to be clarified with system owner:	Is the firm 'UA-Travel' required to notify CERT-UA or another organization in the event of an incident?

IR-3 Incident Response Testing	
1. Control identifier:	IR-3
2. Control name:	Incident Response Testing
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	1st param: at least annually
5. Relevance to this ICS:	Annual testing is realistic for a small organization.
6. Security requirements addressed:	Incident readiness. Verification of plan effectiveness.
7. Risks mitigated:	Discovering plan ineffectiveness only during a real incident.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	1st param: at least annually (tabletop exercises)
10. Proposed enhancements:	Conduct annual tabletop exercises for typical incidents (malware infection, laptop loss, password compromise).
11. Possible compensating control:	—
12. Rationale for the decision:	The parameter is appropriate for a small organization's capabilities.
13. Responsible role:	Head of Security Department
14. Implementation evidence / verification artifact:	Exercise records; test results and findings
15. Information to be clarified with system owner:	—

IR-2 Incident Response Training	
1. Control identifier:	IR-2
2. Control name:	Incident Response Training
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	a.1: 30 working days; a.3: at least annually; b.1: at least annually
5. Relevance to this ICS:	All three officials must receive training according to their roles.
6. Security requirements addressed:	Incident readiness. Personnel competence.
7. Risks mitigated:	Inadequate incident response due to insufficient training.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	a.1: 30 working days from role assignment; a.3: at least annually; b.1: content update at least annually
10. Proposed enhancements:	Include in training: response to malware detection, laptop loss, suspected unauthorized access.
11. Possible compensating control:	—
12. Rationale for the decision:	Parameters are appropriate for the organization's size.
13. Responsible role:	Head of Security Department
14. Implementation evidence / verification artifact:	Training programs; signed training completion logs
15. Information to be clarified with system owner:	Have all three officials completed incident response training?

IR-8 Incident Response Plan	
1. Control identifier:	IR-8
2. Control name:	Incident Response Plan
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	b, d: all personnel with incident response roles or responsibilities
5. Relevance to this ICS:	A specific plan must be developed for UA-Travel's ASVB.
6. Security requirements addressed:	Incident readiness. Structured incident handling approach.
7. Risks mitigated:	Chaotic, ineffective response in the absence of a plan.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	b: distribute to Head of Security, IS Administrator, System Administrator; d: same persons; protect from unauthorized disclosure
10. Proposed enhancements:	Develop and approve Incident Response Plans for typical scenarios: malware infection, OU-classified media loss, unauthorized access, system failure.
11. Possible compensating control:	—
12. Rationale for the decision:	Parameters are appropriate for the organization's structure.
13. Responsible role:	Head of Security Department
14. Implementation evidence / verification artifact:	Approved Incident Response Plan; acknowledgment signatures
15. Information to be clarified with system owner:	Has an Incident Response Plan been developed and approved for the ASVB?

Maintenance

MA-3 / MA-3(1) / MA-3(2) / MA-3(3) Maintenance Tools	
1. Control identifier:	MA-3 / MA-3(1) / MA-3(2) / MA-3(3)
2. Control name:	Maintenance Tools
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	b: at least annually; verify maintenance tools
5. Relevance to this ICS:	The passport contains maintenance records (Section 7). FortiGate and server underwent maintenance.
6. Security requirements addressed:	Integrity, availability. Control of system maintenance tools.
7. Risks mitigated:	Use of unauthorized or compromised maintenance tools for malware implantation.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	b: verify tools at least annually; maintain a register of approved maintenance tools
10. Proposed enhancements:	Expand Passport Section 7: add the list of authorized maintenance tools and integrity checks prior to use.
11. Possible compensating control:	—
12. Rationale for the decision:	Existing maintenance practice is documented in the passport — formalization is required.
13. Responsible role:	IS Administrator

14. Implementation evidence / verification artifact:	Authorized maintenance tools register; Passport Section 7 records; integrity verification records
15. Information to be clarified with system owner:	What external tools or media are used during system maintenance?

MA-4 Nonlocal Maintenance

1. Control identifier:	MA-4
2. Control name:	Nonlocal Maintenance
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — approval, control, MFA, session termination
5. Relevance to this ICS:	FortiGate 60F supports remote management. Whether remote access is used for maintenance is unknown.
6. Security requirements addressed:	Confidentiality, integrity. Remote maintenance control.
7. Risks mitigated:	Unauthorized remote maintenance; session hijacking.
8. Draft decision:	**Clarification required**
9. Proposed parameters for Target Security Profile:	If permitted: MFA for remote maintenance; session recording; terminate connection after maintenance. If prohibited: document the prohibition.
10. Proposed enhancements:	Prohibit remote FortiGate access from the Internet. Allow only from internal network or via VPN.
11. Possible compensating control:	—
12. Rationale for the decision:	Without information on remote maintenance practices, parameters cannot be determined.
13. Responsible role:	Head of Security Department
14. Implementation evidence / verification artifact:	FortiGate management access rules; remote maintenance session log
15. Information to be clarified with system owner:	Is remote maintenance of FortiGate or the server performed? By whom and from where?

MA-5 Maintenance Personnel

1. Control identifier:	MA-5
2. Control name:	Maintenance Personnel
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — authorization, maintenance personnel list, supervision
5. Relevance to this ICS:	JSC 'SERZHANT' provides physical security, not system maintenance. External maintenance specialists are unknown.
6. Security requirements addressed:	Confidentiality, integrity. Control of technical personnel access.
7. Risks mitigated:	Unauthorized access by external technical specialists to OU-classified information.
8. Draft decision:	**Add enhancement**
9. Proposed parameters for Target Security Profile:	Maintain a register of authorized maintenance personnel; ensure escort of external specialists during maintenance
10. Proposed enhancements:	Develop an external maintenance personnel admission procedure: authorization by Head of Security, mandatory escort by IS or System Administrator, registration in Passport Section 7.

11. Possible compensating control:	—
12. Rationale for the decision:	The passport records maintenance events but does not contain an external specialist admission procedure.
13. Responsible role:	Head of Security Department
14. Implementation evidence / verification artifact:	Authorized maintenance personnel register; escort records in Passport Section 7
15. Information to be clarified with system owner:	Are external technical specialists engaged for maintenance? Do they access the system room unescorted?

Media Protection and Contingency Planning

MP-4 Media Storage	
1. Control identifier:	MP-4
2. Control name:	Media Storage
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — physical control and secure storage
5. Relevance to this ICS:	Media containing OU-classified information (backups, removable media) must be stored securely.
6. Security requirements addressed:	Confidentiality, integrity. Protection of media from unauthorized access.
7. Risks mitigated:	Unauthorized physical access to OU-classified media; theft.
8. Draft decision:	**Add enhancement**
9. Proposed parameters for Target Security Profile:	Store OU-classified media in a locked safe or metal cabinet with restricted access (authorized persons only). Maintain a media inventory log.
10. Proposed enhancements:	Establish a physical media inventory log for OU-classified information. Designate a responsible custodian.
11. Possible compensating control:	—
12. Rationale for the decision:	The passport does not mention media storage facilities.
13. Responsible role:	IS Administrator
14. Implementation evidence / verification artifact:	Media inventory log; access keys/codes for storage facilities
15. Information to be clarified with system owner:	Where are backups and removable media containing OU-classified information stored? Is there a safe or metal cabinet available?

MP-2 Media Access	
1. Control identifier:	MP-2
2. Control name:	Media Access
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	1st param: all types of digital and/or non-digital media containing non-public information
5. Relevance to this ICS:	Restrict access to all media containing OU-classified information: HDD, USB, CD/DVD, paper documents.
6. Security requirements addressed:	Confidentiality. Control of access to media.
7. Risks mitigated:	Unauthorized access to OU-classified media.

8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	1st param: all digital (HDD, USB, DVD) and non-digital (paper) media containing OU-classified information
10. Proposed enhancements:	Block USB ports on workstations (except authorized devices) via Group Policy or Loza-1 settings.
11. Possible compensating control:	—
12. Rationale for the decision:	The parameter covers all media types.
13. Responsible role:	IS Administrator
14. Implementation evidence / verification artifact:	Group Policy settings (USB Restriction); Loza-1 configuration; media inventory log
15. Information to be clarified with system owner:	Are USB ports blocked on workstations? Is USB media usage being logged?

MP-6 Media Sanitization	
1. Control identifier:	MP-6
2. Control name:	Media Sanitization
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — sanitize before disposal, release, or reuse
5. Relevance to this ICS:	Applicable when replacing HDDs, transferring the laptop, or disposing of OU-classified media.
6. Security requirements addressed:	Confidentiality. Prevention of OU-classified information recovery from disposed media.
7. Risks mitigated:	Recovery of OU-classified information from improperly sanitized media.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	Sanitize using a method appropriate to the sensitivity level (DBAN or physical destruction for OU-classified media)
10. Proposed enhancements:	Develop a Media Sanitization/Destruction Procedure for OU-classified information and designate a responsible party.
11. Possible compensating control:	—
12. Rationale for the decision:	The parameter meets requirements.
13. Responsible role:	IS Administrator
14. Implementation evidence / verification artifact:	Media sanitization/destruction records; Passport Section 7 records
15. Information to be clarified with system owner:	What is the current procedure when replacing or disposing of HDDs?

MP-3 Media Marking	
1. Control identifier:	MP-3
2. Control name:	Media Marking
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — mark OU-classified media
5. Relevance to this ICS:	All media containing OU-classified information (HDD, USB, paper) must be marked.
6. Security requirements addressed:	Confidentiality. Identification of OU-classified media.

7. Risks mitigated:	Improper handling or unauthorized distribution of unmarked media.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	Mark all applicable media with 'Official Use Only' designation
10. Proposed enhancements:	Establish a marking standard (format, placement, responsible party for marking).
11. Possible compensating control:	—
12. Rationale for the decision:	Marking is mandatory for media containing OU-classified information.
13. Responsible role:	IS Administrator
14. Implementation evidence / verification artifact:	Physical inspection of media markings; marking standard document
15. Information to be clarified with system owner:	Are current media containing OU-classified information properly marked?

MP-5 / SC-28 Media Transport	
1. Control identifier:	MP-5 / SC-28
2. Control name:	Media Transport
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	Protect and control during transport; maintain accountability
5. Relevance to this ICS:	Media containing OU-classified information may be transported during backup operations or staff travel.
6. Security requirements addressed:	Confidentiality, integrity. Protection during transport.
7. Risks mitigated:	Theft or loss of media during transport.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	Document each media transport event; protect during transport (sealed containers, encryption)
10. Proposed enhancements:	Develop a Media Transport Procedure for OU-classified information.
11. Possible compensating control:	—
12. Rationale for the decision:	The parameter meets requirements.
13. Responsible role:	IS Administrator
14. Implementation evidence / verification artifact:	Media transport log; transport procedure
15. Information to be clarified with system owner:	Is media containing OU-classified information transported outside the Controlled Zone? For what purposes?

MP-7 Media Use	
1. Control identifier:	MP-7
2. Control name:	Media Use
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	Restrict or prohibit use; prohibit removable media without identified owner
5. Relevance to this ICS:	USB media is the primary vector for malware infection and information leakage.
6. Security requirements addressed:	Confidentiality, integrity. Control of removable media.

7. Risks mitigated:	System infection via USB media; unauthorized removal of OU-classified information.
8. Draft decision:	**Add enhancement**
9. Proposed parameters for Target Security Profile:	Prohibit use of any unauthorized removable media. Permit only media registered in the inventory with an identified owner.
10. Proposed enhancements:	1) Block USB media via Group Policy (USBSTOR: Deny all). 2) For authorized tasks — issue specific media through the inventory log. 3) Configure Loza-1 for removable media control if supported.
11. Possible compensating control:	—
12. Rationale for the decision:	USB control is critical for an OU-classified system. The passport does not confirm the existence of such control.
13. Responsible role:	IS Administrator; System Administrator
14. Implementation evidence / verification artifact:	Group Policy settings (USBSTOR); authorized media register; Loza-1 configuration
15. Information to be clarified with system owner:	Is USB media use restricted in the system? Is removable media usage logged?

CP-9 / CP-9(8) System Backup	
1. Control identifier:	CP-9 / CP-9(8)
2. Control name:	System Backup
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	a.2: at least weekly; b: at least weekly; c: upon creation/receipt/update; CP-9(8): cryptographic protection of backups
5. Relevance to this ICS:	HP ProLiant DL360 is the primary storage. APC Smart-UPS protects against power outages.
6. Security requirements addressed:	Availability, confidentiality. Recovery capability and backup protection.
7. Risks mitigated:	Irrecoverable loss of OU-classified information upon hardware failure; leakage from unencrypted backups.
8. Draft decision:	**Add enhancement**
9. Proposed parameters for Target Security Profile:	a.2: at least weekly (system backups); b: at least weekly (information backups); c: upon any OU-classified information changes; CP-9(8): backup encryption
10. Proposed enhancements:	1) Develop and approve a Backup Procedure (schedule, responsible party, methodology). 2) Store backups outside the Controlled Zone (separate secured location) or in encrypted form on a separate disk. 3) Quarterly backup restoration test. 4) Encrypt backups per CP-9(8).
11. Possible compensating control:	—
12. Rationale for the decision:	Absence of information about the current backup practice is a critical gap.
13. Responsible role:	System Administrator
14. Implementation evidence / verification artifact:	Backup procedure; backup log; restoration test results; encryption confirmation
15. Information to be clarified with system owner:	Is backup performed? Where are backups stored? Are they encrypted? Has restoration been tested?

Personnel Security

PS-3 Personnel Screening	
1. Control identifier:	PS-3

2. Control name:	Personnel Screening
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — screen before granting access; periodic re-screening
5. Relevance to this ICS:	All three individuals (Kovalenko O.P., Melnyk I.V., Sydorenko I.M.) have access to OU-classified information.
6. Security requirements addressed:	Confidentiality. Reliability of personnel with access to official information.
7. Risks mitigated:	Insider threat or unqualified personnel with access to official information.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	Screening before granting access; re-screening upon position change or after 3 years
10. Proposed enhancements:	Record screening facts in a separate document (screening act or clearance form).
11. Possible compensating control:	—
12. Rationale for the decision:	The parameter meets requirements.
13. Responsible role:	Head of Security Department
14. Implementation evidence / verification artifact:	Personnel screening records; appointment orders; clearance documents
15. Information to be clarified with system owner:	Has each of the three officials been screened prior to being granted access to the ASVB?

PS-4 / PS-5 Personnel Termination and Transfer	
1. Control identifier:	PS-4 / PS-5
2. Control name:	Personnel Termination and Transfer
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	PS-4 a: voluntary — within 5 working days; involuntary — same day; PS-5 b.1: remove/disable all system access no longer required
5. Relevance to this ICS:	Small team — termination of any of the three is a critical security event.
6. Security requirements addressed:	Confidentiality, integrity. Timely access revocation.
7. Risks mitigated:	Active access to OU-classified information after termination or transfer.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	PS-4: voluntary termination — disable access within 5 working days; involuntary — on the day of termination. PS-5: review and adjust access upon transfer.
10. Proposed enhancements:	Include access revocation procedure in the Information Protection Policy; develop a termination checklist (deactivation of Windows, Loza-1, IT-Tour, FortiGate accounts; change shared resource passwords).
11. Possible compensating control:	—
12. Rationale for the decision:	Parameters meet requirements. For a small organization, a checklist is critical.
13. Responsible role:	Head of Security Department; IS Administrator
14. Implementation evidence / verification artifact:	Termination/transfer checklist; account deactivation records
15. Information to be clarified with system owner:	—

Physical and Environmental Protection

PE-2 Physical Access Authorizations	
1. Control identifier:	PE-2
2. Control name:	Physical Access Authorizations
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	c: at least annually
5. Relevance to this ICS:	Office in 'Tsentralnyi' Shopping Center. Security provided by JSC 'SERZHANT'. A controlled access list is required.
6. Security requirements addressed:	Confidentiality, integrity. Control of physical access to the ASVB.
7. Risks mitigated:	Unauthorized physical access to equipment and media.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	c: review physical access list at least annually; update upon personnel changes
10. Proposed enhancements:	Develop and approve a List of Authorized Persons for physical access to ASVB premises. Include in JSC 'SERZHANT' protocol.
11. Possible compensating control:	—
12. Rationale for the decision:	The parameter meets requirements.
13. Responsible role:	Head of Security Department
14. Implementation evidence / verification artifact:	Authorized physical access list; JSC 'SERZHANT' protocols; annual review records
15. Information to be clarified with system owner:	Is an approved list of persons authorized for physical access to the ASVB premises in place?

PE-6 Monitoring Physical Access	
1. Control identifier:	PE-6
2. Control name:	Monitoring Physical Access
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	b.1: at least every 90 days
5. Relevance to this ICS:	Security alarm connected to JSC 'SERZHANT' monitoring station. Log review required.
6. Security requirements addressed:	Confidentiality, integrity. Detection of unauthorized intrusions.
7. Risks mitigated:	Unauthorized physical access not detected due to irregular monitoring.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	b.1: review physical access logs at least every 90 days; immediate review upon suspicious events
10. Proposed enhancements:	Establish a procedure for obtaining and analyzing security alarm logs from JSC 'SERZHANT'. Consider installing CCTV cameras if not already present.
11. Possible compensating control:	—
12. Rationale for the decision:	The parameter meets requirements.
13. Responsible role:	Head of Security Department
14. Implementation evidence / verification artifact:	JSC 'SERZHANT' security alarm logs; 90-day review records

15. Information to be clarified with system owner:	Are access logs maintained by the security alarm system? Are they provided to the firm for analysis?

PE-17 Alternate Work Site

1. Control identifier:	PE-17
2. Control name:	Alternate Work Site
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — define alternate work sites; apply security controls
5. Relevance to this ICS:	ThinkPad X1 Carbon laptop may be used outside the Controlled Zone.
6. Security requirements addressed:	Confidentiality. Protection when working outside the Controlled Zone.
7. Risks mitigated:	Unauthorized access or leakage of OU-classified information when working outside the Controlled Zone.
8. Draft decision:	**Clarification required**
9. Proposed parameters for Target Security Profile:	If permitted: define list of alternate work sites; approve security controls (VPN, BitLocker, prohibition of public network connections without VPN).
10. Proposed enhancements:	Develop Alternate Work Site Rules.
11. Possible compensating control:	—
12. Rationale for the decision:	It is unknown whether remote work or work outside the Controlled Zone is permitted.
13. Responsible role:	Head of Security Department
14. Implementation evidence / verification artifact:	Remote work rules; VPN configuration; authorized alternate work site register
15. Information to be clarified with system owner:	Is remote work or work outside the office permitted? Is the laptop used outside the Controlled Zone for processing OU-classified information?

PE-3 / PE-5 Physical Access Control and Output Device Control

1. Control identifier:	PE-3 / PE-5
2. Control name:	Physical Access Control and Output Device Control
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — entry/exit control, logs, visitor escort, output device control
5. Relevance to this ICS:	Doors equipped with locks and alarm sensors. JSC 'SERZHANT' provides security. HP LaserJet outputs paper documents containing OU-classified information.
6. Security requirements addressed:	Confidentiality, integrity. Prevention of unauthorized physical access and output interception.
7. Risks mitigated:	Unauthorized access to equipment; unauthorized interception of printed documents.
8. Draft decision:	**Add enhancement**
9. Proposed parameters for Target Security Profile:	Control access to the printer: place in restricted-access area; immediately retrieve printed OU-classified documents; log large print jobs.
10. Proposed enhancements:	1) Ensure HP LaserJet is not accessible to unauthorized persons. 2) Establish rule: printed OU-classified documents are immediately retrieved and registered. 3) Verify whether the printer is visible through windows (the premises have 9 windows).
11. Possible compensating control:	—
12. Rationale for the decision:	A printer in a system handling OU-classified information is a potential paper document leakage source. Office in a shopping center increases external observation risk.

13. Responsible role:	Head of Security Department
14. Implementation evidence / verification artifact:	Printer location; print job log; rules for handling printed materials
15. Information to be clarified with system owner:	Where is the printer physically located? Are there access restrictions?

PE-4 Access Control for Transmission Medium	
1. Control identifier:	PE-4
2. Control name:	Access Control for Transmission Medium
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — control physical access to distribution lines and power transmission lines
5. Relevance to this ICS:	The passport indicates: telephone line exits the Controlled Zone unshielded; fire and security alarm cables also run outside the CZ unshielded.
6. Security requirements addressed:	Confidentiality. Protection from technical channel leakage.
7. Risks mitigated:	Technical leakage channel via telephone lines; induction via unshielded alarm cables outside the CZ.
8. Draft decision:	**Add enhancement**
9. Proposed parameters for Target Security Profile:	Document existing technical protection measures (Gnom-VCh-01) in the Target Security Profile. Consider additional measures for the telephone line.
10. Proposed enhancements:	1) Verify effectiveness of Gnom-VCh-01 (vibro-acoustic noise generator) for neutralizing acoustic and TEMPEST channels. 2) For the telephone line exiting the CZ — consider installing a telephone line protection device (line filter). 3) Document technical leakage channels and mitigation measures in an Inspection Report.
11. Possible compensating control:	Gnom-VCh-01 serves as a compensating control for acoustic and vibration channels.
12. Rationale for the decision:	The passport explicitly indicates unshielded lines outside the Controlled Zone — these are potential leakage channels requiring documentation and mitigation.
13. Responsible role:	IS Administrator
14. Implementation evidence / verification artifact:	Technical leakage channel inspection report; Gnom-VCh-01 documentation; cable routing diagram
15. Information to be clarified with system owner:	Has a technical leakage channel inspection been conducted? What is the measurement protocol for Gnom-VCh-01?

Risk Assessment

RA-3 / SR-6 Risk Assessment	
1. Control identifier:	RA-3 / SR-6
2. Control name:	Risk Assessment
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	d, f: at least annually; RA-3(1)b: at least annually; SR-6: at least annually
5. Relevance to this ICS:	Annual risk assessment is the foundation for updating the security profile.
6. Security requirements addressed:	Risk management. Adapting security controls to changes in the threat environment.
7. Risks mitigated:	Inadequate security controls due to outdated risk assessment.
8. Draft decision:	**Keep unchanged**

9. Proposed parameters for Target Security Profile:	d, f: at least annually; unscheduled assessment upon significant system or threat changes
10. Proposed enhancements:	Develop and approve a Risk Assessment Methodology for the ASVB based on ND TZI 3.6-006-24.
11. Possible compensating control:	—
12. Rationale for the decision:	The parameter meets requirements.
13. Responsible role:	IS Administrator; Head of Security Department
14. Implementation evidence / verification artifact:	Risk assessment reports; annual review records; unscheduled assessment records
15. Information to be clarified with system owner:	Has an initial risk assessment been conducted for the ASVB? Is it documented?

RA-5 / RA-5(2) Vulnerability Monitoring and Scanning

1. Control identifier:	RA-5 / RA-5(2)
2. Control name:	Vulnerability Monitoring and Scanning
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	a: at least every 30 days; RA-5(2): update within 24 hours before scanning
5. Relevance to this ICS:	Windows 10 Pro, FortiGate, Cisco — all require regular vulnerability scanning.
6. Security requirements addressed:	Integrity, confidentiality. Timely detection and remediation of vulnerabilities.
7. Risks mitigated:	System compromise via undetected or unpatched vulnerabilities.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	a: scanning at least every 30 days; RA-5(2): signature update within 24 hours before scanning
10. Proposed enhancements:	Use ESET Endpoint Security for basic scanning; consider open-source scanners (e.g., OpenVAS) for network scanning. Document results and remediation plans.
11. Possible compensating control:	—
12. Rationale for the decision:	Parameters meet requirements.
13. Responsible role:	System Administrator
14. Implementation evidence / verification artifact:	Vulnerability scan reports; remediation plans; pre-scan update confirmations
15. Information to be clarified with system owner:	What tool is used for vulnerability scanning? Does it cover all system components?

RA-7 Risk Response

1. Control identifier:	RA-7
2. Control name:	Risk Response
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — respond to assessment findings
5. Relevance to this ICS:	A process for handling identified risks and vulnerabilities is required.
6. Security requirements addressed:	Risk management. Timely mitigation of identified risks.
7. Risks mitigated:	Unaddressed risks due to absence of a formal response process.
8. Draft decision:	**Keep unchanged**

9. Proposed parameters for Target Security Profile:	Critical risks remediated within 30 days; significant within 90 days; low within 180 days or accepted with documentation
10. Proposed enhancements:	Develop a risk response matrix with time frames for each criticality level.
11. Possible compensating control:	—
12. Rationale for the decision:	Time frames are not defined in the baseline profile but are required for the Target Security Profile.
13. Responsible role:	Head of Security Department
14. Implementation evidence / verification artifact:	Risk register; remediation plans; risk closure confirmations
15. Information to be clarified with system owner:	—

Assessment, Authorization, and Monitoring

CA-2 Control Assessments

1. Control identifier:	CA-2
2. Control name:	Control Assessments
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	d: at least annually
5. Relevance to this ICS:	Annual compliance assessment of implemented security controls.
6. Security requirements addressed:	Security management. Confirmation of control effectiveness.
7. Risks mitigated:	Ineffective or improperly implemented controls not detected for years.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	d: at least annually; independent review (external or internal audit)
10. Proposed enhancements:	Include assessment in the annual audit plan (Passport Section 9).
11. Possible compensating control:	—
12. Rationale for the decision:	Parameter meets requirements and aligns with existing practice (Passport Section 9 reviews).
13. Responsible role:	IS Administrator; Head of Security Department
14. Implementation evidence / verification artifact:	Control assessment records (Passport Section 9); audit reports
15. Information to be clarified with system owner:	—

CA-5 Plan of Action and Milestones

1. Control identifier:	CA-5
2. Control name:	Plan of Action and Milestones
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — plan of action and milestones
5. Relevance to this ICS:	Assessment findings must be captured in a remediation plan.
6. Security requirements addressed:	Security management. Systematic remediation of identified deficiencies.

7. Risks mitigated:	Identified deficiencies remain unaddressed due to absence of a systematic approach.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	Maintain and update a Plan of Action and Milestones (POA&M) after every assessment
10. Proposed enhancements:	Develop a POA&M template and maintain it as a living document.
11. Possible compensating control:	—
12. Rationale for the decision:	The parameter meets requirements.
13. Responsible role:	IS Administrator
14. Implementation evidence / verification artifact:	Current POA&M; item closure confirmations
15. Information to be clarified with system owner:	—

CA-7 Continuous Monitoring

1. Control identifier:	CA-7
2. Control name:	Continuous Monitoring
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — continuous monitoring strategy
5. Relevance to this ICS:	Monitoring via FortiGate, ESET, Loza-1, and Windows logs.
6. Security requirements addressed:	Availability, confidentiality, integrity. Continuous security posture tracking.
7. Risks mitigated:	Late detection of violations due to absence of continuous monitoring.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	Develop and document a Continuous Monitoring Strategy for the ASVB
10. Proposed enhancements:	Monitoring elements: antivirus database status (ESET), FortiGate rule status, Windows Security logs, Loza-1 logs. Define review frequency for each element.
11. Possible compensating control:	—
12. Rationale for the decision:	The parameter meets requirements.
13. Responsible role:	IS Administrator
14. Implementation evidence / verification artifact:	Continuous Monitoring Strategy; periodic review reports
15. Information to be clarified with system owner:	—

CA-3 Information Exchange

1. Control identifier:	CA-3
2. Control name:	Information Exchange
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — approved information exchange agreements
5. Relevance to this ICS:	IT-Tour:Agency may interact with external booking systems.
6. Security requirements addressed:	Confidentiality. Control of inter-system data exchange.

7. Risks mitigated:	Unauthorized leakage of official information via uncontrolled connections to external systems.
8. Draft decision:	**Clarification required**
9. Proposed parameters for Target Security Profile:	Document all ASVB connections to external systems and conclude appropriate agreements.
10. Proposed enhancements:	Develop a System Connection Register and ensure agreements are in place for each connection.
11. Possible compensating control:	—
12. Rationale for the decision:	Without information on external connections, compliance cannot be confirmed.
13. Responsible role:	Head of Security Department
14. Implementation evidence / verification artifact:	Connection register; inter-system exchange agreements
15. Information to be clarified with system owner:	Which external systems does IT-Tour:Agency connect to? Are data exchange agreements in place?

System and Communications Protection

SC-7 / SC-7(5) Boundary Protection	
1. Control identifier:	SC-7 / SC-7(5)
2. Control name:	Boundary Protection
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	SC-7(5): deny by default, allow by exception
5. Relevance to this ICS:	FortiGate 60F is the primary perimeter protection tool.
6. Security requirements addressed:	Confidentiality, integrity. Network perimeter control.
7. Risks mitigated:	Unauthorized external connections to the system network.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	SC-7(5): configure FortiGate rules on deny-all, allow-by-exception basis
10. Proposed enhancements:	Document all FortiGate rules and their justifications. Conduct annual rule audit.
11. Possible compensating control:	—
12. Rationale for the decision:	FortiGate 60F provides technical implementation. Deny-all is fundamental for OU-classified systems.
13. Responsible role:	System Administrator
14. Implementation evidence / verification artifact:	FortiGate rules configuration; permitted connection documentation; rule audit reports
15. Information to be clarified with system owner:	Is FortiGate configured on a deny-all basis? Which connections are permitted?

SC-4 Information in Shared Resources	
1. Control identifier:	SC-4
2. Control name:	Information in Shared Resources
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — prevent unauthorized transfer via shared resources

5. Relevance to this ICS:	Shared folders and network resources may contain OU-classified information.
6. Security requirements addressed:	Confidentiality. Prevention of leakage via shared resources.
7. Risks mitigated:	Unauthorized access to OU-classified information via shared network resources.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	Access control for shared resources; verify absence of OU-classified information in publicly accessible resources
10. Proposed enhancements:	Review access permissions on all shared folders on the server. Prohibit shared access without authorization.
11. Possible compensating control:	—
12. Rationale for the decision:	The parameter meets requirements.
13. Responsible role:	System Administrator
14. Implementation evidence / verification artifact:	Shared folder permission settings; shared resource list with access rights
15. Information to be clarified with system owner:	Are there shared network folders in the system? What are the access permissions?

SC-8 / SC-8(1) / SC-28 / SC-28(1) Transmission and Storage Confidentiality and Integrity

1. Control identifier:	SC-8 / SC-8(1) / SC-28 / SC-28(1)
2. Control name:	Transmission and Storage Confidentiality and Integrity
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	SC-28: confidentiality and integrity, all information; SC-28(1): all information, all components and media
5. Relevance to this ICS:	Encryption at rest and in transit is critical for the OU-classified system.
6. Security requirements addressed:	Confidentiality, integrity. Protection from unauthorized access and modification.
7. Risks mitigated:	Interception or unauthorized access to OU-classified information during transmission or storage.
8. Draft decision:	**Add enhancement**
9. Proposed parameters for Target Security Profile:	SC-8: encrypt all network connections carrying OU-classified information (TLS 1.2+); SC-28(1): disk encryption (BitLocker for laptop, encrypted volume on server for OU-classified data)
10. Proposed enhancements:	1) Verify that IT-Tour:Agency uses encrypted protocols for data transmission. 2) Enable BitLocker on the laptop. 3) Consider encrypting the OU-classified information volume on the server.
11. Possible compensating control:	—
12. Rationale for the decision:	Encryption is mandatory for an OU-classified system. The laptop is a mobile device with elevated physical loss risk.
13. Responsible role:	System Administrator
14. Implementation evidence / verification artifact:	BitLocker status; IT-Tour network connection protocols; storage encryption confirmation
15. Information to be clarified with system owner:	Does IT-Tour:Agency use encrypted protocols? Is data on the server encrypted?

SC-10 Network Disconnect

1. Control identifier:	SC-10
2. Control name:	Network Disconnect

3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No more than 15 minutes of inactivity
5. Relevance to this ICS:	FortiGate 60F and Windows settings must support session timeouts.
6. Security requirements addressed:	Confidentiality. Termination of inactive network connections.
7. Risks mitigated:	Unauthorized use of abandoned open network connections.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	Terminate network connections after no more than 15 minutes of inactivity
10. Proposed enhancements:	Configure session timeouts on FortiGate for administrative connections. Verify VPN connection timeouts.
11. Possible compensating control:	—
12. Rationale for the decision:	The parameter meets requirements.
13. Responsible role:	System Administrator
14. Implementation evidence / verification artifact:	FortiGate session timeout configuration; Windows settings
15. Information to be clarified with system owner:	—

SC-12 / SC-13 Cryptographic Key Establishment and Cryptographic Protection

1. Control identifier:	SC-12 / SC-13
2. Control name:	Cryptographic Key Establishment and Cryptographic Protection
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — key management; defined cryptography types
5. Relevance to this ICS:	BitLocker, TLS, VPN (if any) — all require cryptographic key management.
6. Security requirements addressed:	Confidentiality, integrity. Protection of cryptographic keys.
7. Risks mitigated:	Compromise of encryption keys; absence of key backup.
8. Draft decision:	**Refine parameters**
9. Proposed parameters for Target Security Profile:	Define cryptographic protection types: AES-256 for BitLocker; TLS 1.2/1.3 for network connections; compliant with DSTU GOST 28147-89 or approved algorithms. Store BitLocker recovery keys in a secure location outside the system.
10. Proposed enhancements:	Develop a Cryptographic Key Management Procedure: generation, storage, recovery, rotation.
11. Possible compensating control:	—
12. Rationale for the decision:	Specific cryptography types must be defined in the Target Security Profile.
13. Responsible role:	IS Administrator
14. Implementation evidence / verification artifact:	List of applied cryptographic algorithms; key management procedure; BitLocker recovery key backups
15. Information to be clarified with system owner:	Where are BitLocker recovery keys stored? Which cryptographic algorithms does IT-Tour:Agency use?

SC-15 Collaborative Computing Devices and Applications

1. Control identifier:	SC-15

2. Control name:	Collaborative Computing Devices and Applications
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	a: special VTC facilities at approved locations; prohibit remote activation
5. Relevance to this ICS:	Limited applicability to a tourism firm, but relevant for the laptop's built-in camera and microphone.
6. Security requirements addressed:	Confidentiality. Prevention of unauthorized activation of input/output devices.
7. Risks mitigated:	Unauthorized activation of laptop microphone or camera for eavesdropping.
8. Draft decision:	**Add enhancement**
9. Proposed parameters for Target Security Profile:	a: no VTC facilities present; physically block or disable built-in camera and microphone on the laptop if not in use
10. Proposed enhancements:	Disable the built-in camera and microphone on the laptop via BIOS or Group Policy. If necessary — apply a physical camera cover.
11. Possible compensating control:	Gnom-VCh-01 noise generator serves as a compensating control for acoustic protection.
12. Rationale for the decision:	Lenovo ThinkPad X1 Carbon Gen 9 has a built-in camera and microphone, which are potential leakage channels.
13. Responsible role:	System Administrator; IS Administrator
14. Implementation evidence / verification artifact:	Laptop BIOS settings (camera/microphone status); Group Policy configuration
15. Information to be clarified with system owner:	Are the laptop camera and microphone disabled at the hardware or software level?

SC-18 / SC-23 Mobile Code and Session Authenticity	
1. Control identifier:	SC-18 / SC-23
2. Control name:	Mobile Code and Session Authenticity
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — authorization and control of mobile code; session authentication protection
5. Relevance to this ICS:	IT-Tour:Agency v.5.4 may use mobile code (JavaScript, ActiveX). Browser on workstations.
6. Security requirements addressed:	Integrity, confidentiality. Mobile code execution control.
7. Risks mitigated:	Execution of malicious mobile code; session compromise.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	Define and document permitted mobile code and technologies; protection of session tokens
10. Proposed enhancements:	Configure the browser (if used) to restrict mobile code. Verify that IT-Tour:Agency supports secure session authentication.
11. Possible compensating control:	—
12. Rationale for the decision:	Parameters meet requirements.
13. Responsible role:	System Administrator
14. Implementation evidence / verification artifact:	Browser settings; IT-Tour session protection configuration
15. Information to be clarified with system owner:	Does IT-Tour:Agency use a web browser? Which mobile code technologies are involved?

System and Information Integrity

SI-2 Flaw Remediation	
1. Control identifier:	SI-2
2. Control name:	Flaw Remediation
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	c: 30 days after security update release
5. Relevance to this ICS:	Windows 10, ESET, FortiGate, Cisco IOS — all require regular updates.
6. Security requirements addressed:	Integrity. Remediation of known vulnerabilities.
7. Risks mitigated:	System compromise via known vulnerabilities in unpatched software.
8. Draft decision:	**Refine parameters**
9. Proposed parameters for Target Security Profile:	c: 30 days for critical updates; 60 days for important updates; test before applying. CRITICAL: Windows 10 Pro — verify support status (EOS October 2025).
10. Proposed enhancements:	CRITICAL: Verify and plan OS upgrade from Windows 10 to Windows 11, as Windows 10 Pro reaches end of support in October 2025.
11. Possible compensating control:	Until migration to Windows 11 — enhanced monitoring and compensating controls (ESET with updated databases, network isolation).
12. Rationale for the decision:	Windows 10 Pro (22H2) is approaching end of support — this is a critical risk for an OU-classified system.
13. Responsible role:	System Administrator
14. Implementation evidence / verification artifact:	OS and software update log; WSUS/Windows Update reports; FortiGate and Cisco update confirmations
15. Information to be clarified with system owner:	Are there plans to upgrade the OS in connection with Windows 10 EOS? Is the hardware base (Dell OptiPlex, ThinkPad X1) compatible with Windows 11?

SI-3 Malicious Code Protection	
1. Control identifier:	SI-3
2. Control name:	Malicious Code Protection
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	c.1.1: at least weekly; c.1.2: endpoints and entry/exit points; c.2.1: blocking and quarantine; c.2.2: at least the responsible administrator
5. Relevance to this ICS:	ESET Endpoint Security v.10.0 is installed. Scan configuration verification required.
6. Security requirements addressed:	Integrity, confidentiality. Detection and neutralization of malware.
7. Risks mitigated:	System infection via USB media or email.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	c.1.1: at least weekly full scan; c.1.2: endpoints (all 3 workstations) and entry points; c.2.1: blocking and quarantine; c.2.2: notify IS Administrator
10. Proposed enhancements:	1) Verify current ESET settings match required parameters. 2) Ensure antivirus databases update automatically daily. 3) Configure FortiGate for antivirus inspection of network traffic if the license includes it.
11. Possible compensating control:	—
12. Rationale for the decision:	ESET Endpoint Security v.10.0 is present. Configuration compliance with requirements must be confirmed.
13. Responsible role:	System Administrator

14. Implementation evidence / verification artifact:	ESET configuration (scan schedule, detection actions, notification settings); ESET database update log
15. Information to be clarified with system owner:	Is weekly full scanning configured in ESET? Is ESET also installed on the laptop?

SI-5 Security Alerts, Advisories, and Directives

1. Control identifier:	SI-5
2. Control name:	Security Alerts, Advisories, and Directives
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — receive external alerts; distribute internal advisories
5. Relevance to this ICS:	CERT-UA and other organizations publish alerts relevant to OU-classified systems.
6. Security requirements addressed:	Integrity, confidentiality. Awareness of current threats.
7. Risks mitigated:	Unawareness of new threats due to absence of CERT-UA alert subscription.
8. Draft decision:	**Add enhancement**
9. Proposed parameters for Target Security Profile:	Define and document alert sources (CERT-UA, State Service of Special Communications, ESET Threat Intelligence). Define procedure for processing and distributing alerts.
10. Proposed enhancements:	Subscribe to CERT-UA security bulletins. Include alert processing in the IS Administrator's weekly review.
11. Possible compensating control:	—
12. Rationale for the decision:	In the context of ongoing hostilities, threats to Ukrainian systems are extremely relevant. Timely alert receipt is critical.
13. Responsible role:	IS Administrator
14. Implementation evidence / verification artifact:	Security alert subscriptions; register of received and processed alerts
15. Information to be clarified with system owner:	Is the organization subscribed to CERT-UA or State Service of Special Communications bulletins?

SI-4 System Monitoring

1. Control identifier:	SI-4
2. Control name:	System Monitoring
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	b: continuously
5. Relevance to this ICS:	FortiGate, ESET, and Windows Event Log provide baseline monitoring.
6. Security requirements addressed:	Availability, confidentiality, integrity. Detection of attacks and unauthorized actions.
7. Risks mitigated:	Late detection of attacks, infiltrations, or unauthorized access.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	b: continuous monitoring of critical indicators via FortiGate and ESET
10. Proposed enhancements:	Configure automatic alerts in ESET and FortiGate for critical events. Develop an escalation procedure upon detection of anomalous events.
11. Possible compensating control:	—

12. Rationale for the decision:	The parameter meets requirements.
13. Responsible role:	IS Administrator
14. Implementation evidence / verification artifact:	FortiGate and ESET alert settings; escalation procedure
15. Information to be clarified with system owner:	—

SI-12 Information Management and Retention	
1. Control identifier:	SI-12
2. Control name:	Information Management and Retention
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — manage per legislation and internal regulations
5. Relevance to this ICS:	OU-classified information in the tourism sector is subject to legislative retention requirements.
6. Security requirements addressed:	Availability, confidentiality. Legislative compliance.
7. Risks mitigated:	Violation of legislation regarding information retention periods; unauthorized deletion.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	Manage per official information protection legislation; document retention periods for each type of OU-classified information processed in the ASVB
10. Proposed enhancements:	Develop a Records Retention Schedule specifying retention periods for each information type processed in the ASVB.
11. Possible compensating control:	—
12. Rationale for the decision:	Parameters meet requirements.
13. Responsible role:	Head of Security Department
14. Implementation evidence / verification artifact:	Records Retention Schedule; retention period register; legislative compliance confirmation
15. Information to be clarified with system owner:	Which regulations govern retention periods for official information in the tourism sector?

Planning, System Acquisition, and Supply Chain Risk Management

PL-1 / AT-1 / AU-1 / CA-1 / CM-1 / IA-1 / IR-1 / MA-1 / MP-1 / PE-1 / PS-1 / RA-1 / SA-1 / SC-1 / SI-1 / SR-1 Policy and Procedures (All Domains)	
1. Control identifier:	PL-1 / AT-1 / AU-1 / CA-1 / CM-1 / IA-1 / IR-1 / MA-1 / MP-1 / PE-1 / PS-1 / RA-1 / SA-1 / SC-1 / SI-1 / SR-1
2. Control name:	Policy and Procedures (All Domains)
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	All: at least annually; AT-1 / AU-1: all personnel; SR-1: key cybersecurity personnel or authorized person
5. Relevance to this ICS:	All major security domains must be supported by documented policies and procedures.
6. Security requirements addressed:	Security management. Normative basis for all security controls.
7. Risks mitigated:	Absence of formalized procedures leads to inconsistent application of security controls.

8. Draft decision:	**Refine parameters**
9. Proposed parameters for Target Security Profile:	Develop and approve a complete set of internal regulatory documents (policies and procedures) for all domains. Review at least annually and upon significant changes.
10. Proposed enhancements:	Develop a Register of CSPI Regulatory Documents with review deadlines and responsible parties.
11. Possible compensating control:	—
12. Rationale for the decision:	The passport confirms the existence of the IS Regulation, but not all required policies are documented. Remaining documents must be identified and developed.
13. Responsible role:	Head of Security Department; IS Administrator
14. Implementation evidence / verification artifact:	CSPI regulatory document register with approval and review dates
15. Information to be clarified with system owner:	Which specific CSPI regulatory documents have been developed and approved to date?

PL-2 System Security and Privacy Plans

1. Control identifier:	PL-2
2. Control name:	System Security and Privacy Plans
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	a.14, b: at least designated IS personnel; c: at least annually
5. Relevance to this ICS:	The existing passport forms the foundation. A detailed Information Protection Plan must supplement it.
6. Security requirements addressed:	Security management. Comprehensive document describing the protection system.
7. Risks mitigated:	Incomplete or outdated protection plan that does not reflect the actual system state.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	a.14, b: distribute to IS Administrator and Head of Security; c: review at least annually
10. Proposed enhancements:	Develop a complete Information Protection Plan for the ASVB based on the passport and this Target Security Profile.
11. Possible compensating control:	—
12. Rationale for the decision:	Parameters meet requirements and organizational structure.
13. Responsible role:	IS Administrator
14. Implementation evidence / verification artifact:	Approved ASVB Information Protection Plan; annual review records
15. Information to be clarified with system owner:	—

PL-4 Rules of Behavior

1. Control identifier:	PL-4
2. Control name:	Rules of Behavior
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	c: at least annually; d: at least annually or when rules are revised
5. Relevance to this ICS:	All three officials must sign and comply with the Rules of Behavior.

6. Security requirements addressed:	Accountability, confidentiality. Legally documented personnel obligations.
7. Risks mitigated:	Legal exposure upon violations due to absence of signed commitments.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	c: annual acknowledgment and signature; d: annual update or upon changes
10. Proposed enhancements:	Include in Rules of Behavior: prohibition of publishing official information on social media, rules for laptop use outside the Controlled Zone, password rules.
11. Possible compensating control:	—
12. Rationale for the decision:	Parameters meet requirements.
13. Responsible role:	Head of Security Department
14. Implementation evidence / verification artifact:	Signed Rules of Behavior from all three officials; annual acknowledgment records
15. Information to be clarified with system owner:	Have all three officials signed the Rules of Behavior?

SA-8 Security Engineering Principles

1. Control identifier:	SA-8
2. Control name:	Security Engineering Principles
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — apply principles during development or modification
5. Relevance to this ICS:	Applicable when upgrading or modifying system components.
6. Security requirements addressed:	Integrity, confidentiality. Adherence to secure design principles.
7. Risks mitigated:	Introduction of vulnerabilities during system modification due to neglect of security principles.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	Apply 'Defense in Depth', 'Least Privilege', 'Fail Secure' principles in any system modifications
10. Proposed enhancements:	Include a list of security engineering principles in the Information Protection Policy.
11. Possible compensating control:	—
12. Rationale for the decision:	Parameters meet requirements.
13. Responsible role:	IS Administrator
14. Implementation evidence / verification artifact:	Security engineering principles in IS Policy; design decision documentation upon modifications
15. Information to be clarified with system owner:	—

SA-22 Unsupported System Components

1. Control identifier:	SA-22
2. Control name:	Unsupported System Components
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — replace or provide alternatives

5. Relevance to this ICS:	CRITICAL: Windows 10 Pro (22H2) — end of support October 2025. Migration planning is required.
6. Security requirements addressed:	Integrity, confidentiality. Maintaining security of system components.
7. Risks mitigated:	Use of unsupported OS without security patches — critical risk for an OU-classified system.
8. Draft decision:	**Add enhancement**
9. Proposed parameters for Target Security Profile:	Develop a migration plan from Windows 10 to Windows 11 by October 2025. Verify compatibility of IT-Tour:Agency v.5.4 and Loza-1 v.2.0 with Windows 11.
10. Proposed enhancements:	1) Develop OS migration plan (test environment → workstations → laptop). 2) Obtain compatibility confirmation from IT-Tour and Loza-1 vendors. 3) Until migration — apply compensating controls (Internet isolation, enhanced ESET monitoring).
11. Possible compensating control:	Until migration: Internet isolation via FortiGate, enhanced ESET monitoring, blocked USB ports.
12. Rationale for the decision:	Windows 10 Pro (22H2) — EOS October 2025. Use of an unsupported OS in a system processing OU-classified information is a critical risk per SA-22.
13. Responsible role:	System Administrator; Head of Security Department
14. Implementation evidence / verification artifact:	OS migration plan; software compatibility confirmation; migration completion confirmation
15. Information to be clarified with system owner:	Is the hardware base (Dell OptiPlex, ThinkPad X1) compatible with Windows 11? Has compatibility of IT-Tour and Loza-1 with Windows 11 been verified?

SA-9 External System Services

1. Control identifier:	SA-9
2. Control name:	External System Services
3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	No numerical parameters — security requirements for vendors; compliance monitoring
5. Relevance to this ICS:	JSC 'SERZHANT' (physical security), IT-Tour software vendor, Loza-1 vendor.
6. Security requirements addressed:	Confidentiality, integrity. Vendor compliance with security requirements.
7. Risks mitigated:	Confidentiality breach due to inadequate security measures by service providers.
8. Draft decision:	**Clarification required**
9. Proposed parameters for Target Security Profile:	Define security controls for each external service provider; include security requirements in contracts.
10. Proposed enhancements:	Review contracts with JSC 'SERZHANT' and software vendors for confidentiality and security requirements.
11. Possible compensating control:	—
12. Rationale for the decision:	Contractual security requirements are unknown without contract review.
13. Responsible role:	Head of Security Department
14. Implementation evidence / verification artifact:	Vendor contracts with security sections; compliance verification
15. Information to be clarified with system owner:	Do contracts with JSC 'SERZHANT' and software vendors include confidentiality and security requirements?

SR-2 / SR-5 / SR-3 Supply Chain Risk Management

1. Control identifier:	SR-2 / SR-5 / SR-3
2. Control name:	Supply Chain Risk Management

3. Included in baseline profile:	Yes
4. Minimum baseline parameters:	SR-2 b: at least annually; supply chain risk management plan
5. Relevance to this ICS:	Vendors: HP (server), Dell (laptop/workstation), FortiGate (Fortinet), Cisco, Loza-1 (domestic), IT-Tour.
6. Security requirements addressed:	Integrity, confidentiality. Protection from supply chain risks.
7. Risks mitigated:	Compromised components or software from vendors; backdoors in hardware or software.
8. Draft decision:	**Keep unchanged**
9. Proposed parameters for Target Security Profile:	Develop a supply chain risk management plan; review at least annually; procure only from authorized vendors
10. Proposed enhancements:	1) Verify software authenticity (digital signatures) upon installation. 2) Maintain a vendor register with risk ratings. 3) Prioritize domestic vendors for security software.
11. Possible compensating control:	—
12. Rationale for the decision:	Parameters meet requirements.
13. Responsible role:	Head of Security Department
14. Implementation evidence / verification artifact:	Supply chain risk management plan; vendor register; annual review records
15. Information to be clarified with system owner:	—

SUMMARY BLOCKS

A. Controls That Can Remain Unchanged

Total: 52 controls

A. Keep Unchanged	
Identifier	**Control Name**
AC-2	Account Management
AC-3	Access Enforcement
AC-22	Publicly Accessible Content
AT-2 / AT-2(2) / AT-2(3)	Literacy Training and Awareness
AT-3	Role-Based Training
AU-3 / AU-3(1)	Content of Audit Records
AU-5	Response to Audit Logging Process Failures
AU-6 / AU-6(3)	Audit Record Review, Analysis, and Reporting
AU-7	Audit Record Reduction and Report Generation
CM-2	Baseline Configuration
CM-6	Configuration Settings
CM-3	Configuration Change Control
CM-4 / CM-4(2)	Impact Analysis
CM-5	Access Restrictions for Change
CM-8 / CM-8(1)	System Component Inventory
IA-2 / IA-11	Identification and Authentication (Organizational Users)
IA-2(8)	Replay-Resistant Authentication
IA-4 / IA-4(4)	Identifier Management
IA-5(1)	Authenticator Management — Password-Based Authentication
IA-6	Authenticator Feedback
IA-5	Authenticator Management
IR-4	Incident Handling
IR-5 / IR-6 / IR-7	Incident Monitoring and Reporting
IR-3	Incident Response Testing
IR-2	Incident Response Training
IR-8	Incident Response Plan
MA-3 / MA-3(1) / MA-3(2) / MA-3(3)	Maintenance Tools
MP-2	Media Access
MP-6	Media Sanitization
MP-3	Media Marking
MP-5 / SC-28	Media Transport
PS-3	Personnel Screening
PS-4 / PS-5	Personnel Termination and Transfer
PE-2	Physical Access Authorizations
PE-6	Monitoring Physical Access
RA-3 / SR-6	Risk Assessment
RA-5 / RA-5(2)	Vulnerability Monitoring and Scanning
RA-7	Risk Response

CA-2	Control Assessments
CA-5	Plan of Action and Milestones
CA-7	Continuous Monitoring
SC-7 / SC-7(5)	Boundary Protection
SC-4	Information in Shared Resources
SC-10	Network Disconnect
SC-18 / SC-23	Mobile Code and Session Authenticity
SI-3	Malicious Code Protection
SI-4	System Monitoring
SI-12	Information Management and Retention
PL-2	System Security and Privacy Plans
PL-4	Rules of Behavior
SA-8	Security Engineering Principles
SR-2 / SR-5 / SR-3	Supply Chain Risk Management

B. Controls Requiring Parameter Refinement or Enhancement

Total: 29 controls

B. Refine / Enhance	
Identifier	**Control Name**
AC-4	Information Flow Enforcement
AC-6 / AC-6(1) / AC-6(7)	Least Privilege
AC-6(2) / AC-6(5) / AC-6(9) / AC-6(10)	Least Privilege — Privileged Access
AC-7	Unsuccessful Logon Attempts
AC-8	System Use Notification
AC-11 / AC-11(1)	Device Lock
AC-12	Session Termination
AC-19 / AC-19(5)	Access Control for Mobile Devices
AU-2	Event Logging
AU-11	Audit Record Retention
AU-12	Audit Record Generation
AU-8	Time Stamps
AU-9 / AU-9(4)	Protection of Audit Information
CM-7 / CM-7(1) / CM-7(5)	Least Functionality
CM-12	Information Location
IA-3	Device Identification and Authentication
MA-5	Maintenance Personnel
MP-4	Media Storage
MP-7	Media Use
CP-9 / CP-9(8)	System Backup
PE-3 / PE-5	Physical Access Control and Output Device Control
PE-4	Access Control for Transmission Medium

SC-8 / SC-8(1) / SC-28 / SC-28(1)	Transmission and Storage Confidentiality and Integrity
SC-12 / SC-13	Cryptographic Key Establishment and Cryptographic Protection
SC-15	Collaborative Computing Devices and Applications
SI-2	Flaw Remediation
SI-5	Security Alerts, Advisories, and Directives
PL-1 / AT-1 / AU-1 / CA-1 / CM-1 / IA-1 / IR-1 / MA-1 / MP-1 / PE-1 / PS-1 / RA-1 / SA-1 / SC-1 / SI-1 / SR-1	Policy and Procedures (All Domains)
SA-22	Unsupported System Components

C. Controls Requiring Additional Input from the System Owner

Total: 10 controls

C. Clarification Required	
Identifier	**Control Name**
AC-5	Separation of Duties
AC-17 / AC-17(3) / AC-17(4)	Remote Access
AC-18 / AC-18(1) / AC-18(3)	Wireless Access
AC-20 / AC-20(1) / AC-20(2)	Use of External Systems
CM-2(7)	Baseline Configuration — High-Risk Areas
IA-2(1) / IA-2(2)	Multi-Factor Authentication
MA-4	Nonlocal Maintenance
PE-17	Alternate Work Site
CA-3	Information Exchange
SA-9	External System Services

Statistical Summary

Decision Category	Number of Controls
Keep unchanged	52
Refine parameters	10
Add enhancement	19
Apply compensating control	0
Clarification required	10
TOTAL	**91**

Critical Actions Requiring Immediate Attention

#	Issue	Recommended Action
1	Windows 10 Pro — End of Support (EOS October 2025)	Plan migration to Windows 11 before October 2025. Verify software compatibility.

2	No disk encryption (BitLocker) on laptop	Enable BitLocker on Lenovo ThinkPad X1 Carbon immediately.
3	USB ports likely not blocked on workstations	Block USB via Group Policy (USBSTOR: Deny all); permit only authorized devices.
4	No documented Wi-Fi policy for the laptop	Prohibit public Wi-Fi connections or disable the Wi-Fi adapter.
5	Built-in camera and microphone on laptop (potential leakage channel)	Disable via BIOS or Group Policy, or apply a physical camera cover.
6	MFA for privileged accounts — status unknown	Verify Loza-1 v.2.0 MFA capabilities and implement accordingly.